Ihr Internetprovider am Hochrhein

Glasfaser - Richtfunk - TV
Telefonie - Hausverkabelung

RST Datentechnik GmbH
Dr. Rudolf-Eberle-Str. 36
79774 Albbruck

Tel: +49 7753 92170
E-Mail: info@rst.de

Hydra Integration Security Assessment

Masumi Payment Service

Prepared for	Masumi Network
Prepared by	RST Datentechnik GmbH
Report date	28 October 2026
Report version	1.0
Classification	Public
Repository	`masumi-network/masumi-payment-service`
Assessed revision	`origin/dev` at `99686769746d`, 27 October 2026
Original review	`dev` at `f48252c833cb`, 26 October 2026

This assessment is a source and configuration review with focused local tests. It did not test a deployed system. Section 2.1 lists the revisions and their commit hashes. Section 9 states the limits.

Contents

1 Executive summary **3**

2 Engagement overview **6**
2.1 Target and revisions . . . 6
2.2 Scope . . . 6
2.3 Method . . . 7
2.4 Severity, confidence, and evidence labels . . . 8

3 System overview **8**
3.1 Trust boundaries . . . 9
3.2 Head lifecycle and controls . . . 10

4 Follow-up item results **12**
4.1 Item 1: Contest and recovery . . . 12
4.2 Item 2: Init and invite lifecycle . . . 13
4.3 Item 3: Settlement and contract coverage . . . 16
4.4 Item 4: Host controls . . . 19
4.5 Item 5: Release and runtime . . . 20

5 Controls reviewed **21**
5.1 Control summary . . . 21
5.2 Fixes confirmed in later revisions . . . 23
5.3 Coverage matrix . . . 25

6 Accepted risks **26**
6.1 ACC-01. Native E2E stacks use fixed credentials on wildcard listeners . . . 27
6.2 ACC-02. Open Hydra invite nonces remain plaintext at rest . . . 27
6.3 Other accepted risks recorded by the project . . . 28
6.4 Other accepted Hydra design limits . . . 29

7 Observations and upstream limits **29**
7.1 Observations . . . 29
7.2 Upstream Hydra limits . . . 30

8 Testing and verification **30**
8.1 Test results . . . 30
8.2 Dependency audit . . . 32
8.3 Secret scan . . . 33

9 Limitations **33**

A Smart contract checklist **34**
A.1 V2 state machine . . . 35
A.2 State and action edges . . . 38
A.3 Security pattern checklist . . . 39

B Hydra API authorization **40**
B.1 Trust-boundary diagrams . . . 41
B.2 Caller, credential, and exposure . . . 44
B.3 Admin route inventory and impact . . . 45

C L1 transaction retries **46**

D Control evidence **47**
D.1 Fanout limits and transaction size . . . 47

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

D.2 L2 minting guards 48
D.3 Snapshots, restart, and recovery 48
D.4 Wallet signing and deposits 48
D.5 Hydra Host 49
D.6 Container and deployment 49
D.7 Invite lifecycle controls 50

E Evidence bundle **51**

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

1 Executive summary

What was assessed

Masumi Network asked for a security assessment of the Hydra integration in the Masumi Payment Service. Hydra is a Cardano layer-2 protocol. It lets parties make fast payments inside a shared "Head" and settle the result on the Cardano main chain (L1) later.

We reviewed each path that creates, funds, uses, settles, recovers, or administers a Hydra Head. We followed value and authority through the payment API, the database, the Hydra Host, Hydra L2, Cardano L1, and the V2 payment smart contract. The Hydra Host is the service that runs hydra-node processes. The assessment was a source-code review with focused local tests. We did not test a deployed system, and we sent no live chain transactions.

The original review used `dev` at `f48252c833cb` on 26 October 2026. Masumi Network then merged fixes through PRs #1318 and #1321 to #1323 and asked us to confirm five follow-up items. The current status check used `origin/dev` at `99686769746d` on 27 October 2026. It was a targeted closure check, not a new full audit. Section 2.1 lists every revision.

Result at a glance

Open findings	None. No Critical, High, Medium, Low, or Informational finding is open at the assessed revision.
Accepted risks	Two: ACC-01 (Medium) and ACC-02 (Low). Masumi Network accepted both (Section 6).
Follow-up items	Five of five closed within the scopes stated below. Items 2, 4, and 5 rest on checks we ran. Items 1 and 3 rest on operator-reported completion plus the evidence in Section 4.
Dependencies	Zero advisories in the workspace lockfile and in both V2 contract tool lockfiles (Section 8.2).
Release 0.30.0	The published Hydra Host image passed signature, digest, provenance, and SBOM checks (Section 4.5.1).
Smart contract	The V2 payment validator has a reviewed control for 20 of the 26 eUTxO patterns. Five patterns do not apply. One pattern lacks independent live evidence in this review. All 56 Aiken tests pass (Appendix A).
Upstream limits	Three hydra-node limits are recorded. UP-03 is an inferred fund-loss window around Contest. It needs an upstream fix or an independent Contest path (Section 7.2).

VERIFIED: At the original review revision, we found no Critical or High issue. The payment API value paths had guards. The V2 payment contract passed the applicable checks in our 26-pattern checklist. The focused tests passed as recorded in Section 8.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

VERIFIED: The assessed revision contains the firewall control fix (PR #1318), the V2 signing-guide correction (PR #1321), the dependency fix (PR #1322), and the durable Init guards (PR #1323). We checked the merged source paths, the three dependency lockfiles, and both V2 contracts. We also ran Init admission on a disposable PostgreSQL 18.6 database, the Hydra Host suites on Node 24, and the signed invite lifecycle. We did not test a deployed Host. Applied disk encryption and ingress rules were outside the agreed scope.

REPORTED: Masumi Network reports the Contest and recovery item and the settlement and contract item complete. For both items we record the source controls and the retained historical evidence. We did not run a fresh funded-chain recovery or settlement.

Follow-up item status

Item	Area	Status	Basis and limit
1	Contest and recovery	REPORTED	The operator reports completion. We reviewed the contest watch, the signed snapshot store, and a retained recovery drill. No fresh funded recovery run (Section 4.1).
2	Init and invite lifecycle	VERIFIED	All 169 migrations applied. Twelve concurrent Init attempts gave one admission and eleven refusals. Signed invite redemption survived a dropped response and component restarts. Expiry and revoke cleanup passed. No funded Head (Section 4.2).
3	Settlement and contract coverage	REPORTED	The operator reports completion. Fresh offline checks passed 56 payment and 9 registry tests. Rebuilt blueprints match the committed bytes. Retained Preprod records show a registry mint and a dispute settlement (Section 4.3).
4	Host controls	VERIFIED	Source and configuration scope. Private-socket firewall control, ingress guards, key permissions, and backup guidance checked. Nine Node 24 suites passed 212 of 212 tests. Deployed effectiveness not claimed (Section 4.4).
5	Release and runtime	VERIFIED	Release 0.30.0 targets the approved commit. Both publish jobs succeeded. Signature, immutable digest, provenance, and SBOM checks passed. Native catalogue and deployed runtime not claimed (Section 4.5).

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Findings by severity

Severity	Count	Items
CRITICAL	0	
HIGH	0	
MEDIUM	0	
LOW	0	
INFO	0	
ACCEPTED	2	ACC-01, ACC-02

Limits of this assessment

- This was a source and configuration review with local tests. We did not test a deployed Host, an applied firewall, a funded Head, or live chain state.
- The hydra-node binary and the Hydra L1 scripts are upstream code. We did not audit them. Section 7.2 records three upstream limits.
- Items 1 and 3 rest on operator-reported completion. Section 4 states the evidence we hold for each item.
- Section 9 gives the full list of limits.

Recommended next steps

Each recommendation comes from a finding, an observation, or a limit in this report.

Area	Action	Reference
Deployment	Confirm on the production Host that the encrypted key volume, the applied nftables rules, the ingress caps, and the systemd unit match the deployment guide.	Section 9, Appendix D
Deployment	Select the Hydra Host image by its signed immutable digest, not by tag.	Section 4.5.1
Deployment	Verify the mainnet parameter file and its hash before the first mainnet Head.	Section 5
Contest safety	Add a durable Contest retry in hydra-node, or a tested independent L1 Contest path. Test it on a funded Head.	UP-03, Section 7.2
Operations	Before Close, read the net L2 mint and burn each positive unit. Review Heads that started with older ledger limits.	Appendix D
Testing	Run the five observation tests, starting with a near-limit Head.	Section 7.1
Risk register	Revisit ACC-01 and ACC-02 when their stated conditions change.	Section 6

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

2 Engagement overview

2.1 Target and revisions

Repository	`masumi-network/masumi-payment-service`
Languages	TypeScript (Node.js, Express, Prisma, Next.js) and Aiken (Plutus V3).
Hydra version	hydra-node 2.4.1, from the pinned Host image.
Assessment dates	26 to 27 October 2026.

The assessment covered the revisions below. Short hashes in the text refer to this table.

Revision	Commit	Used for
Original review	`f48252c833cbec8f80701c611d2e0d390b82b93d` on `dev`, 26 October 2026.	Full source review, threat model, 26-pattern contract checklist, targeted Jest and Aiken suites, secret scan.
Intermediate `dev` checks	`2b57a633f`, `4e6a46330`, and `de1b97fe3` (PR #1314).	Targeted checks of specific fixes as they landed (Section 5.2).
Earlier local invite test	`b3dc461e93a5a2e40efff03dacef13ca79387a2b`, a local commit not on `dev`.	Five Host and invite suites and the amended redemption-signature suite (Section 8).
Focused source review	`45cb84690c22f814be6b5f38610e90788ff32bbd` on `origin/dev`, 27 October 2026.	Recheck of the Hydra source paths after fixes. Not a new full audit.
Firewall fix	`f12831ce9ad7411aded1468c5ddf7b402d29d24c` (fix commit), merged by PR #1318 as `2183d0d08d88a81805e31ee072ae9c86d78d088a`. Checked on `origin/dev` at `7a68e1db4a09`.	Firewall control patch review and regression check (Section 4.4).
Assessed revision	`99686769746d9663dc2eb26f1f996d74f75b36d2` on `origin/dev`, 27 October 2026.	Merge ancestry of PRs #1321 to #1323, affected paths, three dependency audits, local Init admission, Node 24 Host suites, signed invite integration, V2 contract checks.
Release 0.30.0	Merge commit `a846392ccfc8f5a85aee594ad9441dc90820dab0` on `main`. Its tree `59d36e8ce3fc8776fe4b3175debd147ac4414272` equals the tree of the assessed revision.	Published image verification (Section 4.5.1).

2.2 Scope

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Area	Main paths	Questions
API and UI	`src/routes/api/hydra/**`, the shared payment and purchase routes, `frontend/src/components/hydra/**`	Authentication, object access, secret display, input limits
Hydra Host	`packages/hydra-host/**`, `src/services/hydra-host/**`, `src/services/hydra-invite/**`	Token scopes, provisioning, invites, proxy, process isolation, key storage, denial of service
Protocol client	`src/lib/hydra/**`, `src/services/hydra-connection-manager/**`	Message parsing, signed snapshots, replay, rollback, resource limits
Value paths	`src/services/hydra-*`, `packages/payment-source-v2/src/services/**`	Value balance, UTxO reservations, retries, Close, contest, fanout, recovery
Smart contracts	`smart-contracts/payment-v2/**`, V2 registry	The 26 eUTxO patterns, all redeemers, off-chain parity
Persistence and jobs	`prisma/**`, scheduler jobs	Constraints, lock order, idempotency, restart recovery
Operations	Dockerfiles, Compose files, firewall scripts, `.github/workflows/**`, operator guides	Secrets, pinned versions, container exposure, CI trust, release integrity

Out of scope. The hydra-node binary and the Hydra protocol L1 scripts (upstream code), live deployments, cloud firewalls, the Blockfrost service, and live chain state. An earlier TxPipe audit covers the V1 contracts. This assessment covers the V2 payment contract. Section 6 tracks the accepted risks.

2.3 Method

1. **Inventory.** We listed 1,094 candidate files from names, text matches, imports, and callers.
2. **Threat model.** We listed the actors: an unauthenticated peer, a buyer, a seller, an operator, a Host user, a Host admin, a remote Head participant, hydra-node, and the L1 provider. We marked each trust boundary, signature, and value transfer.
3. **Source-to-sink review.** We followed each input from its entry point to its durable effect: a database write, a signature, or a chain transaction.
4. **Contract review.** We checked each V2 redeemer against its off-chain builder. We applied a 26-pattern eUTxO checklist (Appendix A).
5. **Verification.** We read each candidate finding again with its guards and callers. We tested the former firewall path on the earlier `dev` tree, reviewed the PR #1318 patch, and checked that its fix remains in the assessed revision. We ran 13 targeted Jest suites and both V2 Aiken suites on the earlier tree. The final pass checked the merged code, three dependency lockfiles, and the local checks in Section 4. Section 8 records every test run.

We sent no live transactions.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

2.4 Severity, confidence, and evidence labels

Severity	Meaning
CRITICAL	An attacker can steal funds or keys, or cause a direct loss, with no special precondition.
HIGH	Loss of funds, exposure of keys, or a permanent stuck state, with realistic preconditions.
MEDIUM	A limited loss, a temporary freeze of funds, or a control bypass that needs strong preconditions.
LOW	A small effect, or preconditions that are hard to meet.
INFO	No direct security effect. The item concerns guidance, hygiene, or defense in depth.
Confidence	**Meaning**
High	The path is clear. The guard is absent or wrong in the cited source.
Medium	The path is likely, but it depends on runtime state, configuration, or behavior that we did not test.
Low	The pattern is suspicious but can be a false positive.

Each technical claim carries one of three labels:

VERIFIED — We read the cited source or ran the cited check and saw the result.

REPORTED — A project document, an earlier run, or an operator statement supplies the claim. We did not repeat it.

INFERRED — The claim follows from the verified evidence by reasoning.

Source references use the form `path:line`. The focused source review cites `45cb84690c22`. The firewall check cites `7a68e1db4a09` and fix commit `f12831ce9ad7`. The merge, dependency, and local checks cite `99686769746d`. Historical test counts and the contract checklist cite the original review revision. The validator source is unchanged between the original review and the assessed revision. Appendix E lists the retained evidence files.

3 System overview

The Hydra integration has five main parts.

Payment API — The Masumi Payment Service. It exposes admin routes to manage Hydra Hosts and Heads. It moves buyer payments into a Head when a seller and a buyer share one.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Hydra Host	A separate service that starts and supervises one hydra-node process for each Head. It has an authenticated control plane, a proxy to each node API, and a public exchange plane for invites.
hydra-node	The upstream Hydra implementation. It signs snapshots, and it posts the Init, Close, Contest, and Fanout transactions on L1.
V2 payment contract	An Aiken escrow validator. The same script runs on L1 and inside a Head.
Database	PostgreSQL through Prisma. It stores Heads, participants, reservations, and transactions.

3.1 Trust boundaries

We treat six boundaries as trust boundaries. Diagram 3.1 numbers them: (1) the browser to the payment API, (2) the payment API to the Hydra Host, (3) the Hydra Host to hydra-node, (4) node events to the local database, (5) Hydra L2 to the V2 transaction builders, and (6) L1 settlement back to database state. A remote Head participant is an untrusted party at each boundary that carries its data. Appendix B maps the credential that each caller needs.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

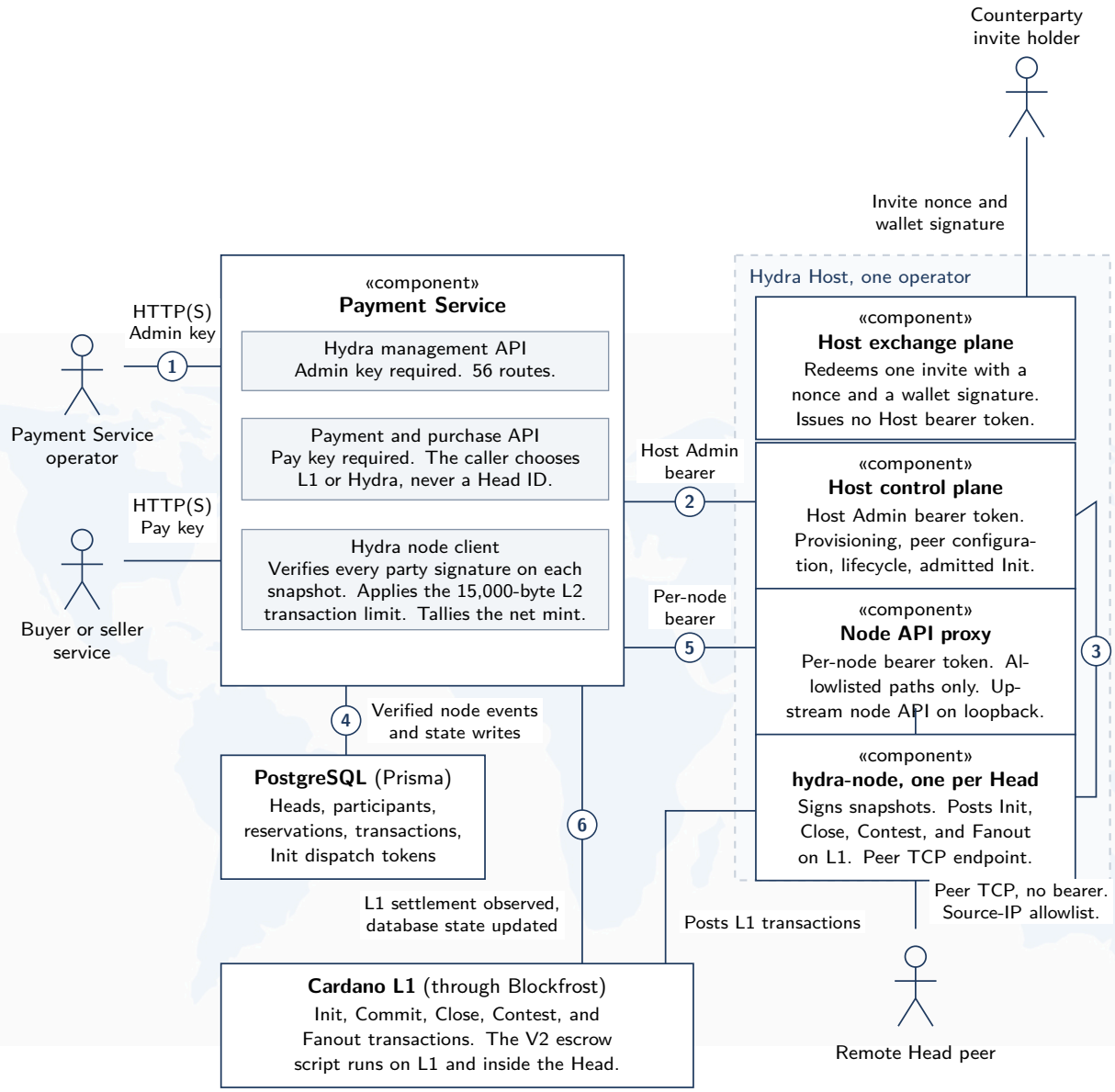
Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Diagram 3.1. Components and trust boundaries



UML component view. Trust boundaries. 1: the browser to the payment API. 2: the payment API to the Hydra Host. 3: the Hydra Host to hydra-node. 4: node events to the local database. 5: Hydra L2 to the V2 transaction builders. 6: L1 settlement back to database state. A remote Head participant is untrusted at every boundary that carries its data. Solid links are communication paths. The dashed enclosure is a security ownership overlay, not a UML privilege flow.

3.2 Head lifecycle and controls

A Head moves through the Hydra protocol states below. At each step the Payment Service or the Hydra Host adds a control. Diagram 3.2 summarizes the controls that this report checked. Appendix C

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

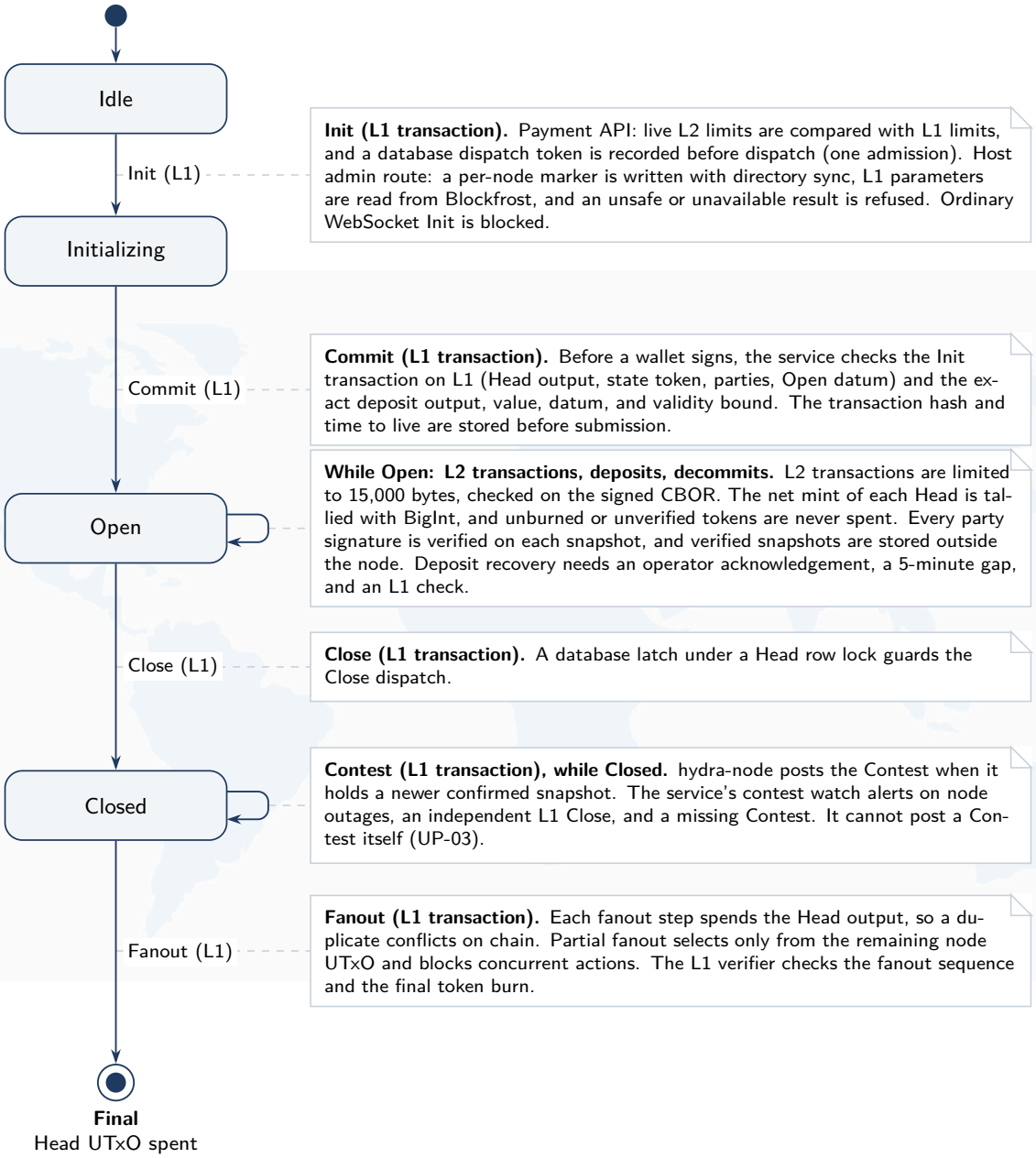
Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

gives the retry behavior of each L1 transaction, and Appendix D gives the source evidence.

Diagram 3.2. Head lifecycle and the controls at each step



VERIFIED: The controls come from Sections 4 and 5 and Appendices C and D. The view omits UTxO pre-split, node funding, and node sweep. It does not change the Hydra protocol states. The view uses UML state machine notation. The filled circle is the initial pseudostate. The bullseye is the final state. The boxes with a folded corner are notes attached to a state or a transition.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

4 Follow-up item results

After the original review, Masumi Network asked us to confirm five follow-up items. Three open questions from the original review belong to these items. Each question is answered in its item below:

- Does a restarted hydra-node contest a Close that it sees while it catches up with the chain? (Item 1)
- If hydra-node gets a second Init before the first one confirms, does it use the same seed input? (Item 2)
- Do organization-level rulesets protect the release tags, and has a signed Host release been verified? (Item 5)

For each item we state the status, what we checked, the result, and the limit of our evidence. Item 4 uses the agreed source and configuration scope, so it does not require a deployment test. The answers to the hydra-node questions use the pinned hydra-node 2.4.1 source.

4.1 Item 1: Contest and recovery

Status	REPORTED Complete, operator reported.
Our evidence	Source controls, a retained recovery drill, and the hydra-node 2.4.1 source.
Not done	A fresh funded-chain recovery run. The UP-03 crash window was not reproduced.

Close during catch-up

VERIFIED: Hydra 2.4.1 processes chain observations while it catches up. An observed Close on an older snapshot emits a Contest transaction when the node retains a newer confirmed snapshot (`hydra-node/src/Hydra/HeadLogic.hs:2054-2061,2110-2114,1263-1285`, tag `2.4.1`). INFERRED: A restarted node with intact state can therefore contest a Close first seen during catch-up, if it reaches and posts the Contest before the deadline. This was not exercised in a live restart drill.

VERIFIED: A separate crash window remains. The node persists the Close before it posts the Contest, but startup retries fanout only (`hydra-node/src/Hydra/Node.hs:302-313,329-337,401-407`, tag `2.4.1`). If the node crashes between those steps, replay can resume after the Close, and no Contest retry is evident. The service's contest watch alerts on a missing Contest, but it cannot post one (`src/services/hydra-contest-watch/watch.ts:198-235`). INFERRED: This is an upstream fund-loss risk, not a demonstrated live exploit. It needs a node-level persistent Contest retry or a tested independent Contest transaction path. Section 7.2 records it as UP-03.

Recovery controls

VERIFIED: The contest watch records node outages and L1 Close alerts (`src/services/hydra-contest-watch/watch.ts:65-145,388-451`). The signed-snapshot store retains verified signatures (`src/services/hydra-snapshot-store/store.ts:50-84`). History replay checks every Head party signature, and the service stores verified signed snapshots outside the node (Appendix D). REPORTED:

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

A project drill on hydra-node 2.3.0 recovered from the loss of one node's storage. The other node closed the Head and fanned out (`docs/hydra-persistence-recovery-verification.md:7-45`). A retained earlier drill found that stock hydra-node rejected a newer snapshot side-load (`docs/hydra-persistence-recovery-verification.md:24,119-133`).

Limit

VERIFIED: This review did not run a fresh restore from the database store or a funded recovery. REPORTED: The operator reports recovery complete. The retained drill and the source checks are narrower evidence than a live recovery.

4.2 Item 2: Init and invite lifecycle

Status	VERIFIED Local integration verified.
Our evidence	Merged source, all migrations on a disposable PostgreSQL 18.6 database, local Init admission checks, two Node 24 suites (46 of 46 tests), and a signed invite integration with component restarts.
Not done	A funded Head, a real hydra-node process, live Blockfrost access, the full production entrypoints, and a production database.

Second Init in hydra-node

VERIFIED: While a first Init is unconfirmed, hydra-node remains Idle and accepts another Init. Each command selects a seed input from the chain-observed wallet. The wallet does not remove a submitted input until it observes a block (`hydra-node/src/Hydra/HeadLogic.hs:127-135,2306-2308`; `Chain/Direct/Handlers.hs:258-268`; `Chain/Direct/Wallet.hs:162-166,189-201,420-424`, tag `2.4.1`). INFERRED: Without an intervening confirmed wallet change, two direct node commands can use the same input and conflict on L1. They cannot both mint a Head identity from that input. The Payment Service and the Host guard their privileged dispatch paths before they send such a second command.

Durable Init guards

VERIFIED: PR #1323 merged into `dev` at `99686769746d`. The payment route conditionally records an Init dispatch token in the database before dispatch (`src/routes/api/hydra/head/init-guard.ts:20-48`; `lifecycle.ts:177-194`). The Host admin route writes a per-node marker before dispatch, rejects a repeated request, and retains the marker after an uncertain outcome (`packages/hydra-host/src/api/privileged-init.ts:17-36`). The Host write requires directory sync, and a sync failure stops dispatch (`packages/hydra-host/src/registry/atomic-write.ts:14-27,31-53`; `store.ts:135-142`). The recovery guide requires positive chain evidence before an operator clears either marker (`docs/hydra-init-dispatch-reconciliation.md:16-33`). These controls close the repeat-dispatch path that the original review tracked.

VERIFIED: Before Init, both the payment API and the Host admin route compare live L2 ledger limits with current L1 limits. The Host reads L1 parameters from Blockfrost through a fixed HTTPS endpoint with a timeout, a response cap, and no redirects. It refuses an unsafe or unavailable result

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

(packages/hydra-host/src/api/privileged-init.ts:19-20; init-admission.ts:28-70,96-135; src/services/hydra-host/init-ledger-admission.ts:34-81). Ordinary Host WebSocket Init is blocked (packages/hydra-host/src/api/proxy.ts:289-304). Diagram 4.1 shows the guards.

Local database checks

VERIFIED: The migration that adds the database token is present (prisma/migrations/20261027000200_hydra_init_dispatch_admission/migration.sql). All 169 migrations applied to a dedicated disposable PostgreSQL 18.6 database. On Node 24.22.1, the local harness gave one admission and eleven HTTP 409 refusals from twelve concurrent Init attempts. A fresh child process refused the persisted token. A stale attempt could not release another attempt's token. After a confirmed pre-dispatch failure, the matching token could release and admit a retry. Disabled and non-Idle Heads were refused. The existing Init route and Host provider suites passed 46 of 46 tests in two suites. No chain dispatch occurred. The harness, its log, and the migration log are in the evidence bundle (Appendix E).

VERIFIED: As a negative control, we removed the dispatch-token check in a temporary copy of the source. The same concurrency test then failed: twelve attempts were admitted instead of one. The repository source stayed unchanged, and the positive run used the checked implementation.

VERIFIED: Before the merge of PR #1323, the Host concurrent-call, restart, uncertain-dispatch, malformed-marker, and sync-failure regressions passed in a focused run of 51 tests on Node 26.7.0. The sync-failure regression failed before the strict-sync change and passed after it.

VERIFIED: For the earlier Init admission fix (PR #1314 at de1b97fe3), five affected Host API Jest suites passed 163 tests. The regression test rejects an unsafe direct-admin Init before node dispatch (packages/hydra-host/src/api/proxy.spec.ts:765-831). The provider tests use an injected fetch stub (init-admission.spec.ts:18-76). No live Blockfrost request or funded Head test was run for this fix.

Invite lifecycle (D7)

REPORTED: The project's implementation plan calls deliverable D7 *Safety properties*. It describes OFFER, ACCEPT, and DECLINE messages with relationId and headSequence (docs/plans/2026-07-28-hydra-host-implementation.md:563-573). VERIFIED: The current signed invite uses a nonce, expiry, network, issuer wallet, keys, peer address, periods, and ledger hash. It does not use those historical fields (src/services/hydra-invite/invite-payload.ts:20-101). The checks below assess the current invite flow, not the old message design. Appendix D.7 records the control evidence.

1. **Replay and signature scope.** VERIFIED: The issuer signs the invite fields above. The redeemer signs the nonce, network, wallet address, keys, peer address, and exchange URL (invite-payload.ts:104-136). Host HTTP tests use real Mesh wallet signatures. They reject altered signed material with 401 and a second valid wallet with 409 (redemption-signature.spec.ts:191-208). The local integration also checks expiry with 410 and database replay counts. The invite signature proves control of its stated wallet, not the operator's intended peer. The operator must check that wallet through a trusted channel (src/services/hydra-invite/invite-signing.ts:86-97). An exposed open nonce can be redeemed by another wallet (ACC-02).
2. **Idempotency after component restart.** VERIFIED: The integration discards the first signed

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

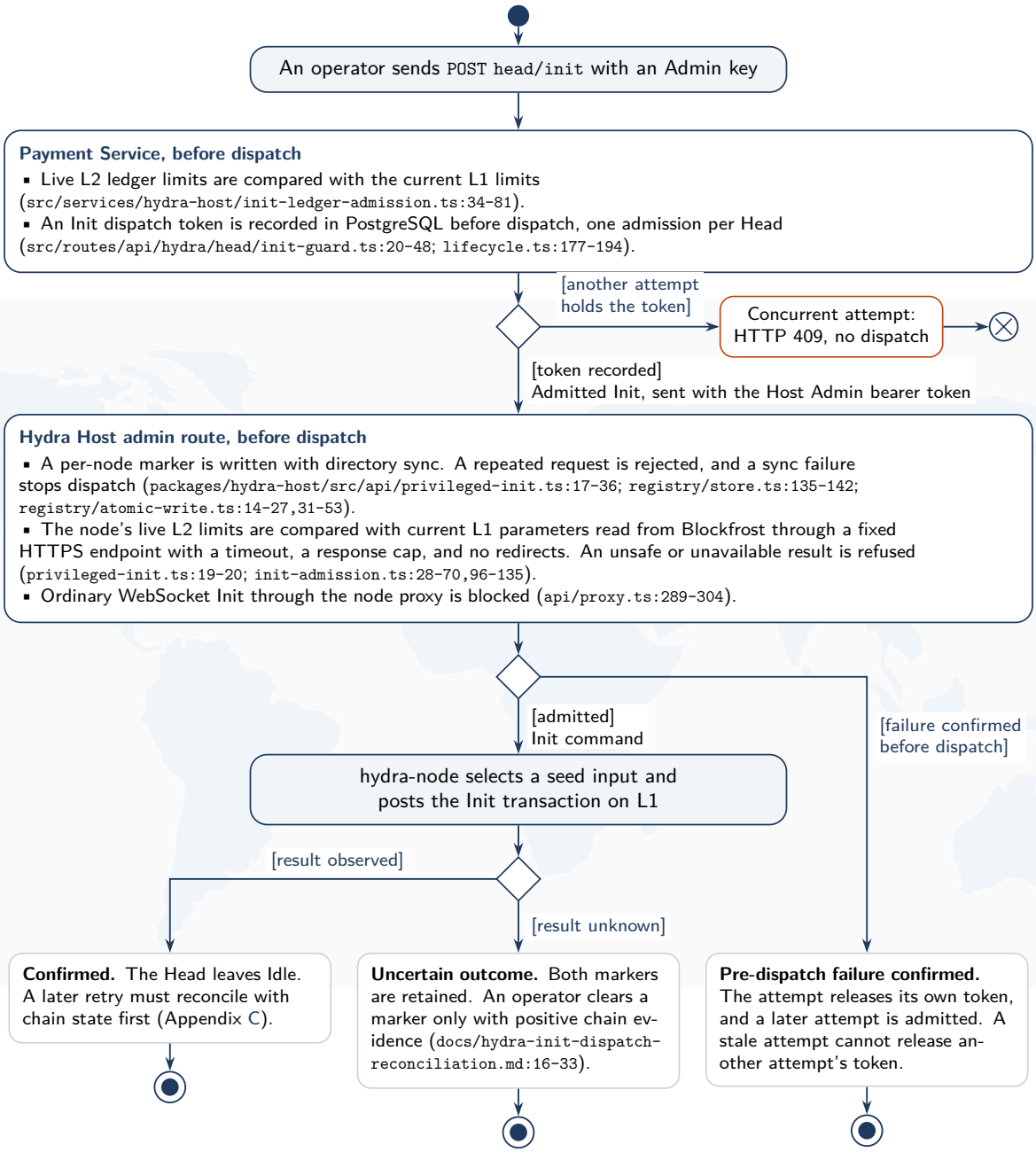
Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Diagram 4.1. Init admission guards



VERIFIED: UML activity notation. A filled circle is the initial node. Rounded boxes are actions. Diamonds are decisions, with guards in square brackets. A circle with a cross ends one flow. A bullseye ends the activity. The checks inside one action are listed, not ordered. Replies to the operator are not drawn, except the HTTP 409 refusal. The local checks below exercised the Payment Service action on a disposable database. The Host action is covered by the pre-merge regression suites recorded in Section 8.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

redemption response, kills and restarts the Host component child, and retries. Its persisted redemption and peer port stay unchanged. Payment Service adoption then runs in a fresh process. The final database state has one invite, one Head, and one local participant. The Host holds one reserved peer port. This uses real Host HTTP, storage, recovery, adoption, and Prisma. It does not start a real hydra-node or the full production entrypoints.

3. **Abandonment and resource release.** VERIFIED: The expiry reaper checks Host redemptions before it forgets an invite and removes a reserved node (`src/services/hydra-invite/adoption.ts:520-592`). Host teardown releases the peer port only after the node record is removed (`packages/hydra-host/src/supervisor/teardown.ts:192-214`). The integration exercises expiry and the Admin revoke route with its authentication. Both paths remove unused local participant and key rows, and Host teardown releases their ports. The active redeemed node and its one reservation remain.
4. **Decline and revoke.** VERIFIED: An Admin can revoke an unredeemed invite and can discard a stuck redemption through the Payment Service route (`src/routes/api/hydra/invite/index.ts:434-632`). The Host Exchange Plane accepts redemption. It has no signed counterparty DECLINE message (`packages/hydra-host/src/api/exchange-server.ts:1-21`). The old plan's immediate decline path is not the current protocol. INFERRED: This design difference alone does not establish a separate security finding.

VERIFIED: The integration runs on Node 24.22.1 against the disposable migrated PostgreSQL database. It uses the actual Host control and exchange HTTP, signature verification, redemption recovery, Payment adoption, Admin route and authentication, withdrawal guards, and teardown. The main phase and a separate Payment retry process both passed. The result record shows an unchanged persisted redemption and peer port. It shows database counts of one invite, one Head, and one local participant. It also shows expiry and revoke key-row cleanup, and one final reserved port (evidence bundle, Appendix E).

Integration limits. VERIFIED: The issued-invite fixture is created directly. The Host component child runs the actual HTTP, store, recovery, and teardown code, but not the full Host entrypoint or the supervisor process lifecycle. Payment adoption runs as a separate component process. The Admin route and its authentication use the endpoint test harness. Blockfrost address responses and hydra-node stop and probe calls are doubled. No real node process, wallet funding, funded Head, or live chain was used.

4.3 Item 3: Settlement and contract coverage

Status	REPORTED Complete, operator reported.
Our evidence	Fresh offline contract tests and builds at the assessed revision, the traced state machine (Appendix A), retained Preprod chain records, and the retained fanout measurement.
Not done	A fresh funded settlement, live edge contention, a multi-output fanout measurement, and a mainnet witness comparison.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

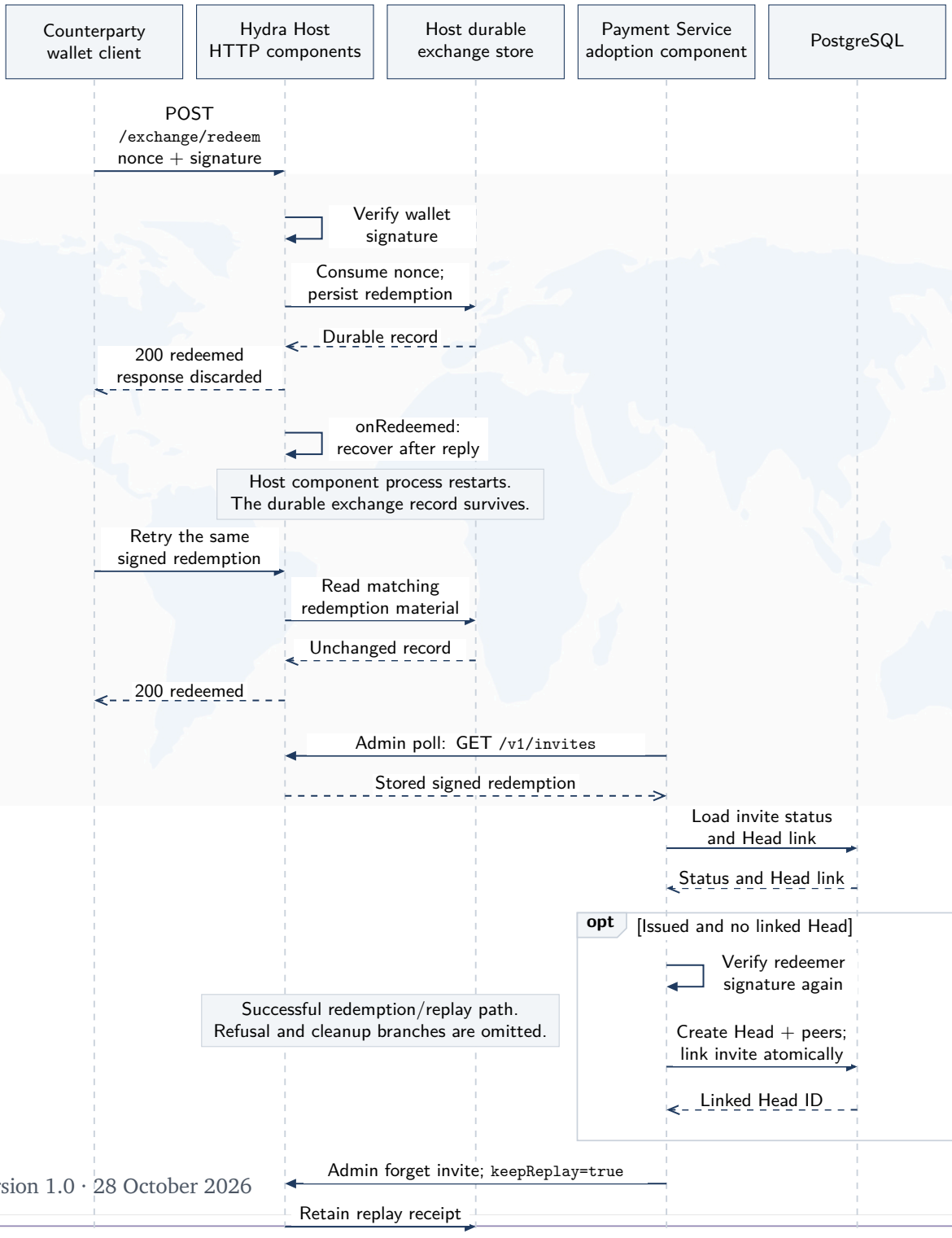
Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Diagram 4.2. Signed invite redemption and restart recovery

VERIFIED: This UML sequence shows the component integration path. Solid arrows are calls. Dashed arrows are replies. The **opt** fragment runs when the invite is Issued and has no linked Head. The test discards the first reply and restarts the Host component process. Refusal and cleanup branches are omitted.



Source: `packages/hydra-host/src/api/exchange-server.ts`, `src/services/hydra-invite/adoption.ts`. Evidence: the invite integration log, the payment retry log, and the result record in the evidence bundle (Appendix E). The full production entrypoints and the funded-chain path remain outside this test.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau
Finanzamt Waldshut-Tiengen
Steuernummer: 20023/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 258 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Contract checks

VERIFIED: Fresh offline `aiken check` runs at `99686769746d` passed 56 of 56 V2 payment tests and 9 of 9 V2 registry helper tests. Isolated builds produced byte-identical committed `plutus.json` files for both contracts. The test summaries are in the evidence bundle. These checks sent no chain transaction. We traced all seven validator actions and their 18 intended state edges (Appendix A).

VERIFIED: A result rotation creates a new UTxO reference, so an admin signature for the old reference cannot settle the new output (`vested_pay.ak:514-519,616-625,643-691`). PR #1321 corrected the signing guide. It now requires fresh admin signatures for the new reference (`smart-contracts/payment-v2/README.md:274-282`). No bypass was demonstrated.

Retained chain records

VERIFIED: The retained registry response in `docs/hydra-l2-milestone4-evidence.tar.gz`, member `2026-m4-preprod/identity/registry-agent.json`, records `RegistrationConfirmed` and mint hash `01a02e927791023a9af3f1ec95bba37157cf0106c285ff1a9d3dff30f96f907b`. REPORTED: The accompanying note and `docs/hydra-l2-milestone4-report.md:110` record a complete Preprod registry mint. The dispute harness sets a 2,000,000-lovelace buyer payout, gives the seller the remainder, and builds tagged payout outputs (`smart-contracts/payment-v2/verify-withdraw-disputed-onchain.mjs:147-175`). The migration record reports an accepted settlement with the current blueprint, transaction `2521fec45ee81f43edde626e6341dc807df938fff70d36ec621eb9e3d7578c0c` (`docs/migrations/v2-contract-cip30-upgrade.md:76-88`). These are retained historical chain records, not fresh chain verification.

Fanout size and snapshot size

REPORTED: The project measured the Hydra 2.4.1 single-output fanout boundary on a three-node local devnet with preprod L1 limits before it set the 15,000-byte L2 cap. A 15,468-byte serialized output fanned out in a 16,384-byte L1 transaction. A 15,469-byte output made a 16,385-byte transaction, which L1 rejected. The measured one-output fanout envelope was 917 bytes (`docs/hydra-fanout-output-size-measurement.md:3-29,45-52`). INFERRED: The 15,000-byte cap leaves at least 467 bytes of margin for this measured one-output case. The record does not give a net L2 mint value or the byte size of a whole snapshot message.

VERIFIED: A separate 2.4.1 Preprod fixture from 7 September 2026 contains three signed snapshot evidence objects with 0, 2, and 13 active UTxOs. Compact UTF-8 JSON of those objects measures 967, 1,942, and 7,719 bytes (`src/lib/hydra/hydra/__fixtures__/recorded-signed-snapshots-2.4.1.json:2`). The objects omit the WebSocket `tag` and `seq` fields, so these are not full message sizes. They predate the 21 October cap run. The 21-output, three-chunk record in `docs/adr/0013-hydra-fanout-settleability.md:19-35` comes from Hydra 2.3, not from the 2.4.1 cap run. These records establish no 2.4.1 multi-output chunk count, cap-run net mint value, or near-limit whole-snapshot frame size.

Limit

VERIFIED: This review did not rerun a funded Head, a live L1 transaction for each edge, or live contention. REPORTED: The operator reports settlement and contract checks complete. Independent

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

live-contention evidence is not retained in this review.

4.4 Item 4: Host controls

Status	VERIFIED Complete within the agreed source and configuration scope.
Our evidence	The firewall patch review and regression check, nine Host suites on Node 24.22.1 (212 of 212 tests), syntax checks of both firewall helpers, and the source and guide for ingress caps, key permissions, and backups.
Not done	Applied Linux packet filtering, deployed ingress rules, encrypted volumes, and backups. No deployment validation is claimed.

Firewall control fix

VERIFIED: A regression setup against the earlier `45cb84690c22` tree showed a fake loopback listener receiving a fake admin token before any response check. At fix commit `f12831ce9ad7`, the helper rejects the TCP setting and uses a private Unix socket. It checks the socket owner and path, and it renders nftables commands from validated peer ports and IPv4 addresses (`packages/hydra-host/scripts/hydra-peer-firewall:131-240`; `packages/hydra-host/src/api/peer-firewall-socket.ts:5-16`). The Host forwards only two admin-authenticated routes on this socket. `origin/dev` at `7a68e1db4a09` contained the fix through the PR #1318 merge, and the assessed revision retains the same script blob. A second source review found no issue to fix in the patch. Three focused Host suites passed 53 of 53 tests, and the pre-push formatting, lint, TypeScript, and generated-file checks passed.

Node 24 Host suites

VERIFIED: On Node 24.22.1, nine Host suites passed 212 of 212 tests. They cover the firewall helper, the egress helper and its attestation, the private socket, control connection limits, HTTP and proxy paths, provisioning, and keys. Both firewall helpers passed `bash -n`. The log is in the evidence bundle.

Ingress, keys, and backups

VERIFIED: Host source caps control connections, and it caps ordinary client WebSocket messages at 4 MiB (`packages/hydra-host/src/api/server-limits.ts:19-24`; `proxy.ts:33,254-258`). The deployment guide requires ingress caps for rate, connections, proxied HTTP bodies, and client WebSocket messages (`docs/hydra-host-deploy-droplet.md:690-738`). The Host writes signing keys as mode 0600 files (`packages/hydra-host/src/api/provision.ts:211-215`). The guide requires a LUKS2 volume, an external unlock secret, and a mount check before Host start (`docs/hydra-host-deploy-droplet.md:54-105`). Appendix D lists the container and deployment evidence.

Limit

VERIFIED: The firewall regression check ran on a macOS machine, so it did not test a Linux firewall or a deployed Host. The Host suites use stub `nft`, `curl`, and `flock` boundaries, so they exercised no packet filtering. They do not prove Linux packet filtering or deployed ingress effectiveness. We did

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

not inspect a deployed Host, its applied ingress rules, its encrypted volume, or its backups. Their deployed state is not determined.

4.5 Item 5: Release and runtime

Status	VERIFIED Complete. Publication and image integrity verified.
Our evidence	Read-only GitHub checks of the release, the workflow run, and the environment rules. Signature, digest, provenance, SBOM, and smoke checks of the published Hydra Host image.
Not done	Native execution of the full script catalogue, live ingress, and deployed Host behavior. Tag rules remain unchanged by operator request.

Release protection

VERIFIED: PR #1319 merged the exact approved source `99686769746d` into `main` as `a846392ccfc8`. Release 0.30.0 targets that commit. The configured `hydra-host-release` environment allows only tag `0.30.0`, requires reviewer `schaier-io`, and contains the dedicated signing secret. The Host publication job requires the release commit to be an ancestor of `main` (`.github/workflows/ghcr.yml:53-67`). The operator-approved job completed in run 40531649900, which reports `hydra_host_publish: success` and `docker_publish: success`. Only the image manifest and its signature are attached to the release. REPORTED: The operator requested no tag-rule changes. No new tag-immutability guarantee is claimed.

4.5.1 Published image verification

Release	`0.30.0`, published as a prerelease.
Merge commit	`a846392ccfc8f5a85aee594ad9441dc90820dab0`
Tested tree	`59d36e8ce3fc8776fe4b3175debd147ac4414272`. The merge commit and the assessed `dev` revision have this same tree.
Host image	`ghcr.io/masumi-network/masumi-payment-service-hydra-host`
Signed index	`sha256:6da66dd17b1ee4a70802a74c413cb8ad81d19a334feaac5826b109914cee2ff5`
Platform	`linux/amd64`. The index has no arm64 image.
Public-key anchor	DER SHA-256: `3aa8ab28256d3114dec0649fbb7e1535a09504bf49843f507f8befc0e83a9fec`

VERIFIED `openssl dgst -sha256 -verify release-public.pem -signature hydra-host-image.txt.sig hydra-host-image.txt` returned "Verified OK". The repository's `verify-release-image` script also accepted the expected image, tag, and commit. The private signing key is outside the repository and this report.

VERIFIED The tag's raw index and the immutable index have identical bytes. Their SHA-256 equals the signed index above. Both the image configuration and the provenance identify `a846392ccfc8`. The image labels identify release `0.30.0`.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

VERIFIED The attestation descriptor chain passed byte-length and SHA-256 checks. Both in-toto subjects equal the index's `linux/amd64` image digest. The retained payloads are SLSA provenance v1 and SPDX 2.3.

VERIFIED A smoke probe ran the immutable image with `--network=none --read-only` and exited 0. It reported Node v24.22.1, uid and gid 10001, hydra-node `2.4.1-099f5dd775d8640047d0074edef294c1b39a600d`, and etcd 3.5.35. Four documentation assets were readable. This checks versions and assets under local amd64 emulation. It does not run a funded node or the full script catalogue.

The release records, the signed manifest, the public key, the attestation payloads, and the smoke probe output are in the evidence bundle (Appendix E).

Local image preflight

VERIFIED: A local preflight of the Hydra Host image found Undici 6.29.1 and Zod 4.6.6 installed. The runtime reports Node 24.22.1, uid 10001, etcd 3.5.35, hydra-node 2.4.1, and release metadata `0.30.0` at `99686769746d`. The full script-catalogue command exited with `SIGILL` under amd64 emulation. This is a partial local preflight. It does not replace the published-image checks above, and it does not establish catalogue, signature, or deployed-runtime behavior.

Scope and limits

VERIFIED: The provenance has an empty `builder.id`, and it declares incomplete resolved dependencies. Its presence does not establish a SLSA assurance level or a reproducible build. The SBOM records the package inventory. This check is not a fresh vulnerability scan of every image package. Full native catalogue execution, live ingress, and deployed Host behavior remain unverified. Select this image by its signed immutable digest.

5 Controls reviewed

This section summarizes the source controls that the original review and the targeted `dev` reviews checked. Each row names its evidence. A row records a source control, not a deployed-system test. Section 9 states the remaining limits.

5.1 Control summary

Area	What we checked	Evidence
Payment API authorization	All 56 Hydra payment API route handlers require an admin key. No raw payment API route or WebSocket upgrade bypasses this check. The payment and purchase routes accept only a layer choice (L1 or Hydra), never a Head ID.	Appendix B
API key and wallet scope	A scoped API key cannot select a Head or a wallet outside its scope. The L2 lock uses only the wallets that the key allows, and it respects the wallet spending limits.	`l2-lock-helpers.ts:199-205`

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Area	What we checked	Evidence
L1 transaction retries	Commit, top-up, decommit, node funding, and deposit recovery store the transaction hash and time to live before submission. The pre-split has a validity bound. Close uses a database latch. A duplicate fanout or sweep conflicts on chain.	Appendix C
Snapshot verification	History replay checks every Head party signature. The service stores verified signed snapshots outside the node. The operator reports recovery complete. A retained earlier drill rejected a newer snapshot side-load. **Limit:** this review did not run a fresh restore from the database store.	Appendix D
Wallet signing	Before a wallet signs a commit, the service checks the Init transaction on L1 and the exact deposit output, value, datum, and validity bound.	Appendix D
Ledger and fanout limits	Before Init, both the payment API and the Host admin route compare live L2 ledger limits with current L1 limits. The Host reads L1 parameters from Blockfrost and refuses unsafe or unavailable results. Ordinary Host WebSocket Init is blocked. L2 transactions are limited to 15,000 bytes, and the service checks the signed size before submission.	Appendix D
L2 minting	The service never builds an L2 mint. It counts the net mint of each Head with `BigInt`, and it does not spend unburned or unverified tokens.	Appendix D
Host proxy routing	The proxy always targets `127.0.0.1`, checks the node ID format, and accepts only allowlisted paths and query parameters. A node-derived token cannot reach another node. Ordinary WebSocket sessions reject Init. We found no path to server-side request forgery or path traversal.	Appendix D
Invites	The exchange plane verifies the wallet signature before it uses the single-use nonce. Redemption requires the issuer address that the redeemer expects. Body size, concurrency, and request rate are limited.	Appendix D.7
Webhooks	Delivery uses the address that passed validation, so DNS rebinding cannot redirect it. Hydra alerts go only to endpoints of the same payment source.	`pinned-request.ts`, `hydra-source.ts`
Node keys	Keys come from `crypto.randomBytes(32)`. The Host writes peer keys together with their node record and cleans up failed provisioning. Ordinary node reads return verification keys. Admin provisioning returns signing keys while escrow is pending, including matching retries, and stops after acknowledgement. The guide requires an encrypted key volume. **Limit:** its applied state was not inspected.	Appendix D
Secrets and logs	Host tokens and node keys are encrypted in the payment database. The tracked-file scan found no key pattern. Open invite nonces remain plaintext in the payment database and in the Host exchange file (ACC-02).	Section 8

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Area	What we checked	Evidence
Frontend	The Hydra UI renders peer data as text only, uses password inputs for tokens, and stores no Hydra secret in the browser.	`frontend/src/components/hydra`
Container	Base images are pinned by digest. The Host runs as user 10001. The base Compose file publishes control ports on loopback, and node APIs bind to loopback. The production host-network setup makes the Host control listener available on all interfaces, subject to ingress rules. Host source caps control sockets and ordinary client WebSocket messages.	Appendix D
Firewall refresh	The root helper uses a private Unix socket for the admin call. It checks the socket owner and path, rejects the former TCP setting, and renders nftables commands from validated peer ports and IPv4 addresses. The Host forwards only two admin-authenticated routes on this socket.	`hydra-peer-firewall:131-240`; `peer-firewall-socket.ts:5-16`
CI workflows	All actions are pinned by commit SHA, and job permissions are minimal. The Host release workflow produces a digest signature, provenance, and an SBOM. The published Host image signature, digest chain, provenance, and SBOM are verified in Section 4.5.1. Tag rules remain unchanged by operator request.	`.github/workflows`
Mainnet parameters	Mainnet needs a parameter file and its hash. The service and the Host enforce a mainnet period floor. A reviewed file and its hash still need deployment verification.	`provisioning.ts`
V2 payment contract	Of the 26 eUTxO patterns, 20 have a reviewed control with no exploit found, 5 do not apply, and 1 lacks independent live-contention evidence in this review. The operator reports contract checks complete. All 56 Aiken tests pass.	Appendix A

5.2 Fixes confirmed in later revisions

Each row records a fix that we confirmed in the source at the stated revision. These are source and document checks, not deployed-system tests.

Revision	Fix confirmed	Source
`dev` at `2b57a633f`	The contest watch records node outages and L1 Close alerts. The signed-snapshot store retains verified signatures. The L2 reservation guide no longer gives unsafe release SQL.	`src/services/hydra-contest-watch/watch.ts:65-145,388-451`; `src/services/hydra-snapshot-store/store.ts:50-84`; `docs/hydra-l2-reservation-recovery.md:48-89`

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Revision	Fix confirmed	Source
Targeted `dev` review	The Host proxy rejects unframed GET and DELETE bodies. Documentation assets are cached. Token rotation rebuilds sessions. Pre-split transactions have a validity bound.	`packages/hydra-host/src/api/proxy.ts:92-105`; `docs-assets.ts:7-35`; `src/services/hydra-host/registry.ts:370-399`; `src/services/hydra-topup/pre-split.ts:216-245`
Targeted `dev` review	The Host applies mainnet period floors. Top-up and decommit take row locks in the same order, and a manual top-up blocks an unabsorbed deposit. The invite UI masks the nonce. The catalogue uses a reviewed hash. The workflow action pins were updated.	`packages/hydra-host/src/config.ts:132-161`; `src/services/hydra-decommit/execute.ts:281-286`; `src/services/hydra-topup/execute.ts:183-194`; `frontend/src/components/hydra/HydraInviteDetailsDialog.tsx:40-60`; `src/services/hydra-host/reviewed-catalogue.ts:12-26`; `.github/workflows/dev.yml:15-25`
Targeted `dev` review	The operator documents state the L1 fallback limits, the release and mainnet parameter requirements, the actual Host controls, the runtime token scope, and the replay anchor.	`docs/hydra-operations.md:29-37,60-66,440-452`; `docs/hydra-host-deploy-droplet.md:853-876`; `docs/security.md:92-97`; `docs/hydra-persistence-recovery-verification.md:76-82`
`origin/dev` at `4e6a46330`	The Host admin Init route checks the node's live L2 parameters and the current L1 parameters from Blockfrost before dispatch. It refuses an unsafe or unavailable result. The request uses the existing project file, a fixed HTTPS endpoint, a timeout, a response cap, and no redirects.	`packages/hydra-host/src/api/privileged-init.ts:19-20`; `init-admission.ts:28-70,96-135`
`origin/dev` at `45cb84690c22`	We rechecked Host authentication, proxy routing, Init admission, L2 size and mint checks, node recovery, the V2 contract, Docker settings, and the firewall helper. This tree includes the top-up and commit exclusion from PR #1315. **Limit:** we did not rerun the earlier suites or conduct a new full audit of later `dev` changes.	`src/services/hydra-topup/blocking.ts:27-55`; `src/services/hydra-commit-reconciliation/index.ts:67-75`
`origin/dev` at `7a68e1db4a09`	The firewall fix is present through the PR #1318 merge. The firewall script and socket-server blobs match the fix commit (Section 4.4).	`packages/hydra-host/scripts/hydra-peer-firewall:131-240`; `packages/hydra-host/src/api/peer-firewall-socket.ts:5-16`

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Revision	Fix confirmed	Source
`origin/dev` at `99686769746d`	The V2 guide correction (PR #1321, merge `bb8ff6122528`), the dependency fix (PR #1322, merge `961995dba17b`), and the durable Init guards (PR #1323, merge `99686769746d`) are present. Their branch commits are ancestors of this ref. We checked the affected source and lockfiles. **Limit:** this was not a new full audit.	Sections 4.2, 4.3, and 8.2

5.3 Coverage matrix

This matrix connects each requested Hydra check to the evidence in this report. "Source checked" means that we inspected a code path, not that a deployed system passed.

Requested area	Result	Remaining limit
Hydra path coverage	**Source checked.** VERIFIED: API, Host, node client, value, persistence, contract, Docker, and CI paths were inventoried (Section 2).	Later `dev` changes had targeted checks only.
Caller access and impact	**Source checked.** VERIFIED: The 56 Payment Service Hydra routes need an Admin key. Host, Pay, Read, counterparty, and peer scopes are mapped in Appendix B.	Inspect the deployed ingress.
Invite lifecycle (D7)	**Local integration verified.** VERIFIED: Real PostgreSQL, signed Host HTTP, recovery, adoption, and teardown passed dropped-response and component-restart checks (Section 4.2).	Production entrypoints, wallet funding, real hydra-node processes, and a funded Head were outside the run.
V2 contract states	**Complete, operator reported.** REPORTED: Settlement and contract checks are reported complete. VERIFIED: Seven actions, 18 intended state edges, and 26 patterns were traced. Fresh `aiken check` passed 56 of 56 payment tests (Appendix A).	Live edge contention was not rerun. Independent evidence is not retained here.
V2 builder, hash, collateral	**Tested path.** VERIFIED: The builder loads the committed blueprint and sets collateral (patterns 20, 21, and 25). Fresh builds match both committed blueprints. REPORTED: Retained Preprod records include a registry mint and a dispute settlement (Section 4.3).	A mainnet witness comparison and a fresh live phase-2 failure were not run.
Fanout size and chunks	**Complete, operator reported.** REPORTED: Settlement checks are reported complete. The retained Hydra 2.4.1 single-output boundary is 15,468 bytes accepted and 15,469 rejected, with 917 bytes of overhead. VERIFIED: The L2 cap is 15,000 bytes (Section 4.3).	Multi-output fanout was not rerun. No 2.4.1 chunk measurement is retained.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Requested area	Result	Remaining limit
L2 mint and snapshot size	**Complete, operator reported.** REPORTED: Settlement checks are reported complete. VERIFIED: `BigInt` net-mint tally, unburned-token guard, 4 MiB frame bound, and 4,095-output bound (Appendix D, OBS-01).	Near-limit snapshots were not rerun. Whole-snapshot bytes and cap-run net mint are not retained.
Node recovery and Contest	**Complete, operator reported.** REPORTED: The operator reports this follow-up complete. A retained 2.3.0 one-node loss drill completed. VERIFIED: Signed snapshot replay and outage or Close alerts exist (Section 4.1).	No fresh funded recovery run. The inferred UP-03 crash window remains a stated limit.
Docker and firewall	**Source and configuration scope complete.** VERIFIED: Pinned image configuration, uid 10001, loopback APIs, private-socket firewall control, ingress guards, and key and backup guidance were checked. Nine Node 24 suites passed 212 of 212 tests (Section 4.4).	Applied Linux rules, ingress effectiveness, encrypted volumes, and backups are outside the agreed scope.
Dependencies	**Merged, audits clean.** VERIFIED: All three audits on the assessed revision report zero advisories after PR #1322 (Section 8.2).	Check rebuilt images and the Node 24 runtime.
Second Init	**Source and local database verified.** VERIFIED: Twelve concurrent attempts gave one winner and eleven HTTP 409 refusals. Persistence, stale-token refusal, release and retry, and state guards passed (Section 4.2).	No chain dispatch, funded Head, or production database was used.
Release chain	**Complete, publication verified.** VERIFIED: Release 0.30.0 targets `a846392ccfc8`. Both publish jobs succeeded. Host digest, signature, provenance, and SBOM checks passed (Section 4.5.1).	Native catalogue and deployed-runtime behavior are not established.
Accepted risks	**Recorded.** REPORTED: ACC-01 and ACC-02 were accepted. Six other register entries and two Hydra design limits appear in Section 6.	Revisit each when its stated condition changes.
Dispute signing guide	**Merged.** VERIFIED: The README requires new admin signatures after a result rotation (PR #1321, Appendix A).	Live settlement was not run.

6 Accepted risks

Masumi Network accepted the two risks below. Each entry records the evidence, the acceptance basis, and the condition that should trigger a new review. The project's own accepted-risk register and two Hydra design limits follow for completeness.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

6.1 ACC-01. Native E2E stacks use fixed credentials on wildcard listeners

Severity	MEDIUM ACCEPTED
Confidence	High for the source path. Medium for reachability, which depends on the machine.
Location	`scripts/hydra-e2e/env.mts:79-82,107-127`

VERIFIED The native end-to-end scripts build fixed Host tokens and fixed payment API admin keys (`scripts/hydra-e2e/env.mts:79-82,107-127`, `demo.mts:35-49`, `two-nodes.mts:65-104`).

VERIFIED The Host and the payment API listen with a port number only, which binds all interfaces (`packages/hydra-host/src/index.ts:313-317`, `src/app.ts:407-421`).

INFERRED If another machine can reach a developer machine that runs these stacks, a person who knows the repository can authenticate to them. The stacks use preprod only.

Masumi Network accepted this risk for the test harness on 26 October 2026. It does not apply to production Host settings.

Acceptance basis and revisit condition

REPORTED: The acceptance covers the native preprod test harness only. The fixed tokens and wildcard binds are present in the harness source (`scripts/hydra-e2e/env.mts:79-82,107-127`; `packages/hydra-host/src/index.ts:313-317`). INFERRED: Preprod scope limits the assets at risk, but it does not stop a reachable machine from accepting those known credentials. Revisit this choice if the harness runs on a shared runner or on a machine that untrusted hosts can reach.

Optional hardening

Bind the harness listeners to `127.0.0.1`. Generate new tokens for each run.

6.2 ACC-02. Open Hydra invite nonces remain plaintext at rest

Severity	LOW ACCEPTED
Confidence	High for storage. The effect is inferred.
Location	`prisma/schema.prisma`; `packages/hydra-host/src/registry/exchange-store.ts`

VERIFIED The payment database stores `HydraHeadInvite.nonce` as plaintext. The Host stores open invite nonces in `/data/exchange.json` with mode 0600 (`docs/security.md:129-134`).

INFERRED A reader of an open nonce can redeem that invite with a wallet before its seven-day expiry. The likely effect is loss of the reserved slot and the intended counterparty, not transfer of issuer funds.

REPORTED The operator accepted this risk on 27 October 2026 in `docs/security.md:133`, in place

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

of the nonce-encryption PR #1300.

Treat database and Host backups as secret material. After a backup leak, revoke open invites and issue new ones.

Acceptance basis and revisit condition

REPORTED: The Host already keeps each Head's signing keys under `/data`. Encryption of `exchange.json` alone would add another key and a migration without protection for those more valuable keys. A leaked nonce can affect an open invite for at most seven days (`docs/security.md:129-135`). INFERRED: The main effect is loss of the intended counterparty's slot. A valid participant signature is still needed to move funds. Revisit this choice if invite redemption can move funds, if the invite lifetime grows, or if node keys gain encryption at rest (`docs/security.md:135`).

6.3 Other accepted risks recorded by the project

REPORTED: The six entries below come from the project's accepted-risk register (`docs/security.md:75-127`). They are recorded here for completeness. They are not new audit findings, and they have no new severity rating. The executive-summary count of two covers ACC-01 and ACC-02 only. Deployment assumptions in these entries were not checked on a live system.

- **API key hashing before lookup.** VERIFIED: Payment API authentication runs PBKDF2-SHA512 before the database lookup (`packages/payment-core/src/auth-middleware.ts:64`; `api-key-hash.ts:20-25`). INFERRED: Many invalid reachable requests can delay valid payment and Hydra requests. REPORTED: The project accepts this because the payment API must sit behind a network allowlist. Revisit it before public ingress. Add ingress rate limits or change the hash design (`docs/security.md:79-84`). The Hydra Host does not use this hash.
- **Preprod secrets in pull-request CI.** REPORTED: Pull-request jobs execute branch code with preprod wallet and Blockfrost secrets. The project accepts this for internal branch writers and preprod-only credentials. Revisit it if production secrets enter those jobs or if branch write access widens (`docs/security.md:86-90`). Repository membership and GitHub Environment settings were not inspected.
- **Host admin secret reused as a runtime secret.** VERIFIED: If registration omits `userToken`, the service stores the admin token in the runtime slot, and node calls derive per-node tokens from that slot (`src/services/hydra-host/registry.ts:279-300`; `src/services/hydra-connection-manager/head-configuration.ts:84-103`). REPORTED: One key simplifies setup, so the project accepts the shared secret under its network allowlist. A separate user token limits the exposed scope. Revisit this on networks outside operator control. Rotate the runtime token when an admin token that was copied there is cleared (`docs/security.md:92-99`).
- **Public secrets during a first seed.** VERIFIED: An unset `ADMIN_KEY` selects a published default, and a first seed can store it as an active admin key. The seed refuses a public key if an active admin already exists (`prisma/seed.admin-key.ts:13-16,25-47`). Interactive seeding asks for confirmation. Non-interactive seeding warns and continues (`prisma/seed.public-secrets.ts:49-74`). REPORTED: This permits local or one-off setup without secret preparation. Revisit it if the service is public or if a deployment template seeds automatically. Set private values before a

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

production seed (`docs/security.md:101-112`).

- **Shared user for Host and hydra-node processes.** VERIFIED: The Host image runs as uid 10001 and starts its nodes under that user (`packages/hydra-host/Dockerfile:253-275`). INFERRED: Code execution in one node can read another Head's signing keys and the Host process environment. REPORTED: The project accepts one operator trust boundary per Host. Per-head users or containers would add privileged process control. Revisit it if a Host serves several operators or if a node exploit becomes known (`docs/security.md:114-120`).
- **Generated wallet mnemonics in seed output.** VERIFIED: The seed prints newly generated phrases to stderr (`prisma/seed.validation.ts:57-68`; `prisma/seed.ts:374,659`). REPORTED: The operator accepted this to permit backup of a wallet created during seeding. Treat captured output as wallet secret material. Revisit it before unattended mainnet seeding or broader log access (`docs/security.md:122-127`).

6.4 Other accepted Hydra design limits

REPORTED: Peer traffic is readable to an on-path observer. The project accepted this and left a tunnel as a future configuration choice (`docs/adr/0015-hydra-host-provisioning-and-exposure.md:199-202`).

REPORTED: A retire decision can use a stale stored contest deadline if the service missed a contest while its live socket was down. The node still contests on its own. The design record accepts this remaining gap (`docs/adr/0013-hydra-fanout-settleability.md:165-188`). This is an operator decision limit, not proof that a missed contest is harmless.

7 Observations and upstream limits

7.1 Observations

Each observation has a plausible path but no measured effect. We recommend a test for each one.

ID	Observation	Suggested test
OBS-01	The client limits one WebSocket message to 4 MiB and one snapshot to 4,095 outputs (`src/lib/hydra/hydra/schemas.ts:8,331-335`). No separate whole-snapshot size guard proves that a 4,095-output snapshot fits that frame limit. Many outputs with many assets can hit 4 MiB first.	Build a near-limit Head. Check node events, replay, and settlement.
OBS-02	The Close proof cleanup scans and sorts error rows on each scheduler pass, and no index matches its filter (`src/services/hydra-close-admission/stale-evidence.ts:18-40`).	Read the query plan on a table of realistic size.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

ID	Observation	Suggested test
OBS-03	The low-balance monitor queues each webhook endpoint inside one database transaction (`src/services/hydra-low-balance/monitor.ts:82-111`).	Find the endpoint count at which the transaction times out.
OBS-04	The invite path accepts a 300-second deposit period (`src/services/hydra-invite/provisioning.ts:224-251`). A project drill found that 300 seconds can miss activation when the chain indexer lags (`docs/hydra-persistence-recovery-verification.md:48-53`).	Measure the indexer lag. If necessary, raise the minimum.
OBS-05	The owner epoch fences database writes, but two service instances can still compete for one Head (`docs/adr/0014-hydra-head-ownership-and-fencing.md:91-120`).	Run one active owner for each Head until lease admission exists.

7.2 Upstream Hydra limits

These limits come from hydra-node, not from this code base. Local controls and unresolved gaps are stated for each one.

- **UP-01. One output that fanout cannot distribute blocks the final fanout.** Hydra 2.4.1 checks a fanout chunk before fee balancing. After balancing, a chunk can exceed its execution budget (`docs/adr/0013-hydra-fanout-settleability.md:38-45,67-84`). Local guard: the 15,000-byte L2 transaction limit leaves a 467-byte margin for a fanout of one output (Appendix D).
- **UP-02. A token minted on L2 and not burned blocks finalization.** Partial fanout can release the other outputs, but outputs with the token stay in the Head (`https://github.com/cardano-scaling/hydra/issues/2334`). Local guard: the service never mints on L2, counts the net mint of each Head, and does not spend unburned tokens. It cannot stop another participant from minting.
- **UP-03. A crash between Close persistence and Contest submission can lose the automatic Contest.** VERIFIED: Hydra 2.4.1 records the observed Close before it posts the Contest effect (`hydra-node/src/Hydra/Node.hs:335-337,401-407`). Recovery replays fanout effects, but no Contest retry is evident (`Node.hs:302-313`). INFERRED: A crash in that interval can leave an old Close uncontested until the deadline. The payment service alerts on the gap, but it has no independent Contest sender (`src/services/hydra-contest-watch/watch.ts:198-235`). This path needs an upstream durable retry or a tested independent L1 Contest path. It was not reproduced on a funded Head (Section 4.1).

8 Testing and verification

8.1 Test results

The table lists every test run that this report relies on, with the revision that it ran against. REPORTED: The counts for the original review come from that review's record at `f48252c833cb` and were not rerun. VERIFIED: The other rows are runs made during this assessment. Section 2.1 lists each

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

revision.

Check	Revision	Result
Host ledger parameters and managed Init (Jest)	Original review	2 suites, 43 of 43 tests pass.
L2 submission and signed L1 transaction size (Jest)	Original review	4 suites, 79 of 79 tests pass.
`aiken check` in `smart-contracts/payment-v2`	Original review	56 of 56 tests pass.
`aiken check` in `smart-contracts/registry-v2`	Original review	9 of 9 helper tests pass.
Close and recovery suites (Jest)	Original review	50 of 50 tests pass.
Invite, alert, webhook, and snapshot suites (Jest)	Original review	83 tests pass. One socket test could not open a port in the review environment.
Host suites: peer firewall, peer egress, egress attestation, peer allowlist, node arguments, and configuration	Original review	111 of 111 tests pass.
`docker compose config` for the base and public-peer files	Original review	Valid. Control ports on loopback. Peer ports 5001 to 5032 on all interfaces.
`bash -n` on the firewall scripts	Original review	Valid syntax. This does not test packet filtering.
Offline run of a cached Host image	Original review	User 10001, Node 24.22.1, hydra-node 2.4.1, etcd 3.5.34. The image predates the original review revision.
Five affected Host API suites for PR #1314	`de1b97fe3`	163 tests pass. The Host package build and the production-file lint pass. The pre-push type checks, lint, formatting, and generated-file checks pass.
Three focused Host suites for the firewall fix	`7a68e1db4a09` with fix `f12831ce9ad7`	53 of 53 tests pass. The pre-push checks pass.
13 targeted Jest suites: ledger caps, net-mint tally, replay, signed snapshots, firewall socket and script paths, contest watch, snapshot storage, partial fanout, and node arguments	Checked `dev` tree	204 of 204 tests pass, including 40 of 40 firewall tests.
Earlier local invite test: five Host and invite suites	Local commit `b3dc461e93a5`, not on `dev`	149 of 149 tests pass. The amended redemption-signature suite passes 8 of 8 tests.
Host regressions for PR #1323, before merge	Fix branch	51 tests pass: concurrent call, restart, uncertain dispatch, malformed marker, and sync failure. The sync-failure regression failed before the strict-sync change and passed after it.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Check	Revision	Result
x402 and frontend suites for PR #1322, before merge	Fix branch	198 x402 tests pass with 2 skipped. 417 frontend tests pass. Both type checks, lint, and formatting pass.
Node 24 smoke check for PR #1322	Fix branch	Both type checks pass. Real Zod 4 V2 parsing passes.
`aiken check` for both V2 contracts	Assessed revision	56 of 56 and 9 of 9 tests pass. Rebuilt blueprints are byte-identical to the committed files.
Prisma migrations on disposable PostgreSQL 18.6	Assessed revision	All 169 migrations applied.
Local Init admission harness	Assessed revision	1 admission and 11 HTTP 409 refusals from 12 concurrent attempts. A fresh process refuses the persisted token. Stale-token refusal, own-token release and retry, and state guards pass. The negative control fails with 12 admissions.
Init route and Host provider suites	Assessed revision	2 suites, 46 of 46 tests pass.
Nine Host control suites	Assessed revision	212 of 212 tests pass. Both firewall helpers pass `bash -n`.
Signed invite integration: main phase and Payment retry process	Assessed revision	Both pass (Section 4.2).
Backend and frontend TypeScript checks	Assessed revision	Exit code 0 for each check.
Published Hydra Host image checks	Release 0.30.0	Signature, digest chain, provenance, SBOM, and smoke probe pass (Section 4.5.1).
Full Hydra suites and live-chain suites	Later revisions	Not run. No deployed fix is claimed.

Runtime note. The project targets the Node 24 line. The original review's TypeScript tests, the PR #1314 run, the firewall-fix run, the 13-suite run, and the earlier local invite test used Node 25.8.1, which is outside that range. The pre-merge runs for PRs #1322 and #1323 used Node 26.7.0. The nine Host suites, the Init admission harness, the signed invite integration, and the TypeScript checks on the release source used Node 24.22.1. The two Init route and provider suites used Node 24.

REPORTED: The earlier PR CI record marked the E2E checks for PRs #1280 to #1300 as canceled. In PR #1279, three V1 E2E tests passed, while the V2 setup stopped on `UTxO Fully Depleted` (run 40440419872). Neither result verifies the assessed revision.

8.2 Dependency audit

VERIFIED: PR #1322 merged into `origin/dev` at `961995dba17b85f39d73b0bcdcc32559585d6e47`. The assessed revision is `99686769746d`. The workspace and both V2 contract lockfile blobs match the merged fix branch. The workspace resolves Zod 4.6.6, and each V2 contract tool resolves Undici 6.29.1.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Checked lockfile and command	Result on fetched `dev`, 27 October 2026
Workspace, `pnpm audit --json`	Zero info, low, moderate, high, and critical advisories.
V2 payment tool, `npm audit --json`	Zero info, low, moderate, high, and critical advisories.
V2 registry tool, `npm audit --json`	Zero info, low, moderate, high, and critical advisories.

VERIFIED: Before the merge, `dev` at `7a68e1db4a09` reported a High Zod 3 advisory and High and Moderate Undici advisories in the standalone V2 tools. Those results describe the older tree, not the current dependency status. No reachable Hydra request path that exploits those advisories was established.

VERIFIED: Before the merge, the fix branch passed 198 x402 tests with 2 skipped, 417 frontend tests, both type checks, lint, and formatting on Node 26.7.0. A local Node 24.22.1 smoke check passed both type checks and real Zod 4 V2 parsing. On the fetched `dev` tip, the dependency-audit pass reran the three advisory lookups only. INFERRED: The three checked lockfiles have no currently reported advisory. **Limit:** the dependency-audit pass did not check rebuilt images, a deployed payment API, or a live chain E2E. The local Host image preflight in Section 4.5 found Undici 6.29.1 and Zod 4.6.6 installed.

8.3 Secret scan

A search of the tracked files for AWS keys, live Stripe keys, PEM private keys, and mnemonic phrases found no match at the original review. The only tracked environment files are `.env.example`, `frontend/.env.example`, and `jest.setup.env.ts`. At `45cb84690c22`, a second local pattern scan found no high-confidence AWS, GitHub, Stripe, or PEM credential. Database URLs with credentials appeared only in examples, test files, and local Hydra scripts. A pattern search cannot prove that no secret exists.

9 Limitations

The original audit reviewed source and focused tests at `f48252c833cb`. A focused pass checked the Hydra-related source paths at `45cb84690c22`. A later check at `7a68e1db4a09` verified the firewall merge. The check at the assessed revision `99686769746d` verified three more merges, the affected source paths, three dependency audits, and the local checks in Sections 4 and 8. This was not a new full audit. These checks do not guarantee that the code is free of defects. The limits below describe our evidence. They do not dispute the operator-reported completion of items 1 and 3.

- **Upstream code.** The hydra-node binary and the Hydra protocol L1 scripts were not audited.
- **Deployed systems.** A deployed Host, a live firewall, a funded Head, and live chain state were not tested. Applied Linux packet filtering is outside the agreed source and configuration scope.
- **Init in production.** The merged Init migration in a production database and funded Init retry behavior were not tested. All migrations and the local admission and retry guards passed on disposable PostgreSQL 18.6. A local Host image preflight was partial. Their deployed state is not determined.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

- **Blockfrost.** Live Blockfrost access and its failure behavior for the Host admin Init admission were not tested. The local provider tests used a fetch stub.
- **Mainnet script witness.** A byte-for-byte comparison of a current mainnet V2 script witness with the source was not done. The configured address checks and the recorded Preprod spends cover the tested paths (Appendix A).
- **Recovery.** This review did not run a fresh restore of Host or node storage. The operator reports recovery complete. Signed snapshots are stored. A retained earlier drill found that stock hydra-node rejected a newer snapshot side-load (`docs/hydra-persistence-recovery-verification.md:24,119-133`).
- **Invite integration.** The full production entrypoints, a real hydra-node process, wallet funding, and a funded Head were outside the invite run. The local integration covers real PostgreSQL, signed Host HTTP, component restarts, adoption, expiry, and revoke cleanup (Section 4.2).
- **Host key storage.** VERIFIED: The Host writes signing keys as mode 0600 files (`packages/hydra-host/src/api/provision.ts:211-215`). The deployment guide requires a LUKS2 volume, an external unlock secret, and a mount check before Host start (`docs/hydra-host-deploy-droplet.md:54-105`). We did not inspect a deployed volume or its backups. Their encryption status is not determined.
- **Control-plane ingress.** VERIFIED: Host source caps control connections, and it caps ordinary client WebSocket messages at 4 MiB (`packages/hydra-host/src/api/server-limits.ts:19-24`; `proxy.ts:33,254-258`). The deployment guide requires ingress caps for rate, connections, proxied HTTP bodies, and client WebSocket messages (`docs/hydra-host-deploy-droplet.md:690-738`). We did not inspect or test applied ingress rules. Their deployed effectiveness is not determined.
- **Release tags and runtime.** Tag rules remain unchanged by operator request. No new tag-immutability guarantee is claimed. The published Host signature and digest evidence is verified separately (Section 4.5.1). The full native amd64 catalogue command and the deployed runtime were not validated.

A Smart contract checklist

We applied this checklist to `smart-contracts/payment-v2/validators/vested_pay.ak`. The validator defines seven actions: Withdraw, SetRefundRequested, AuthorizeWithdrawal, WithdrawRefund, WithdrawDisputed, SubmitResult, and AuthorizeRefund (lines 75-94). The compiler is Aiken `v1.1.23` with Plutus V3.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

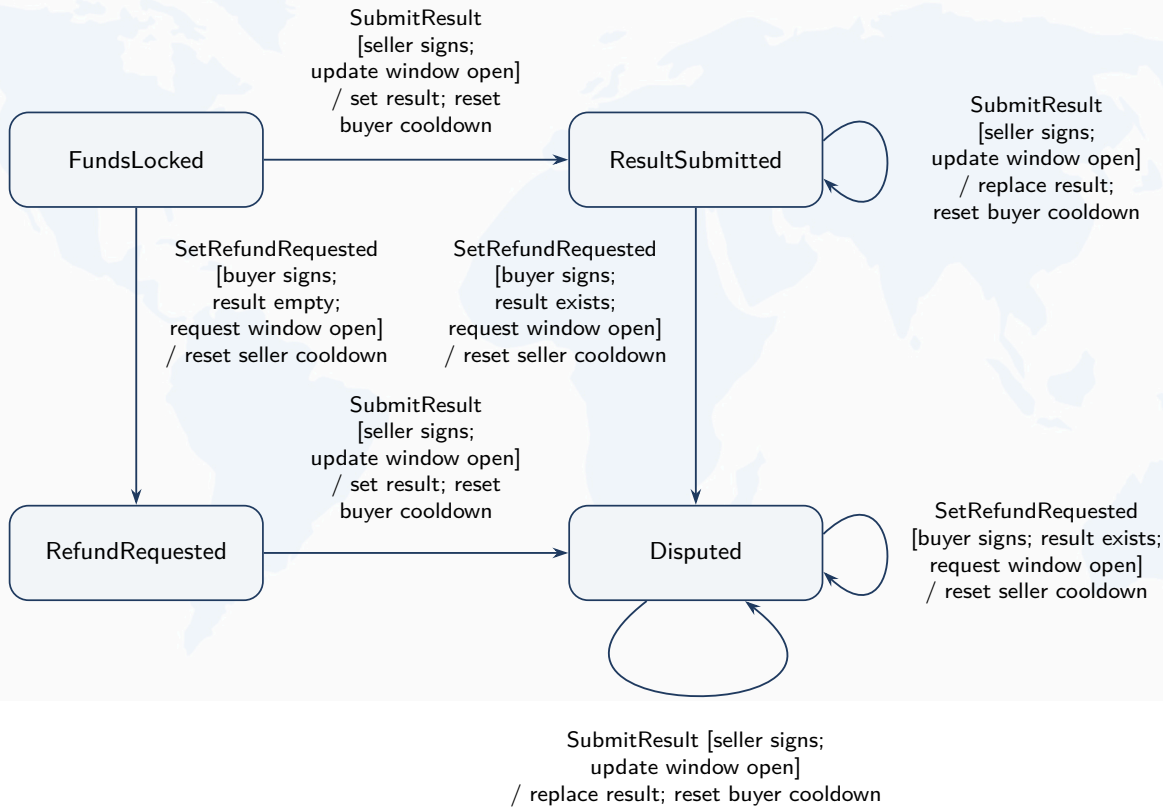
A.1 V2 state machine

VERIFIED: The V2 datum has six states (`vested_pay.ak:32-60`). The three state views below describe valid, builder-created escrow outputs. Lock creation is outside this spending validator. Each continuing action spends one UTxO and creates a new UTxO with a checked datum and at least the input value (`vested_pay.ak:349-403,460-502,643-760,769-770`). Each actual state appears once per view. The views share the same six-state model.

Notation. Rounded boxes are datum states. Arrows use *action [guard] / effect*. Bullseyes mark consumed escrow UTxOs. The views have no initial marker because the spending validator does not validate lock creation. Notation reference: OMG UML 2.5.1, Sections 14 and 17.

Diagram A.1. Result updates and refund requests

VERIFIED: Seven transitions change the continuing datum.



Every transition creates a continuing escrow UTxO and preserves its value. The guard table defines the update and request windows, including cooldowns. The two loops at Disputed are distinct transitions.

Source: `vested_pay.ak:349-403` and `vested_pay.ak:643-700`.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

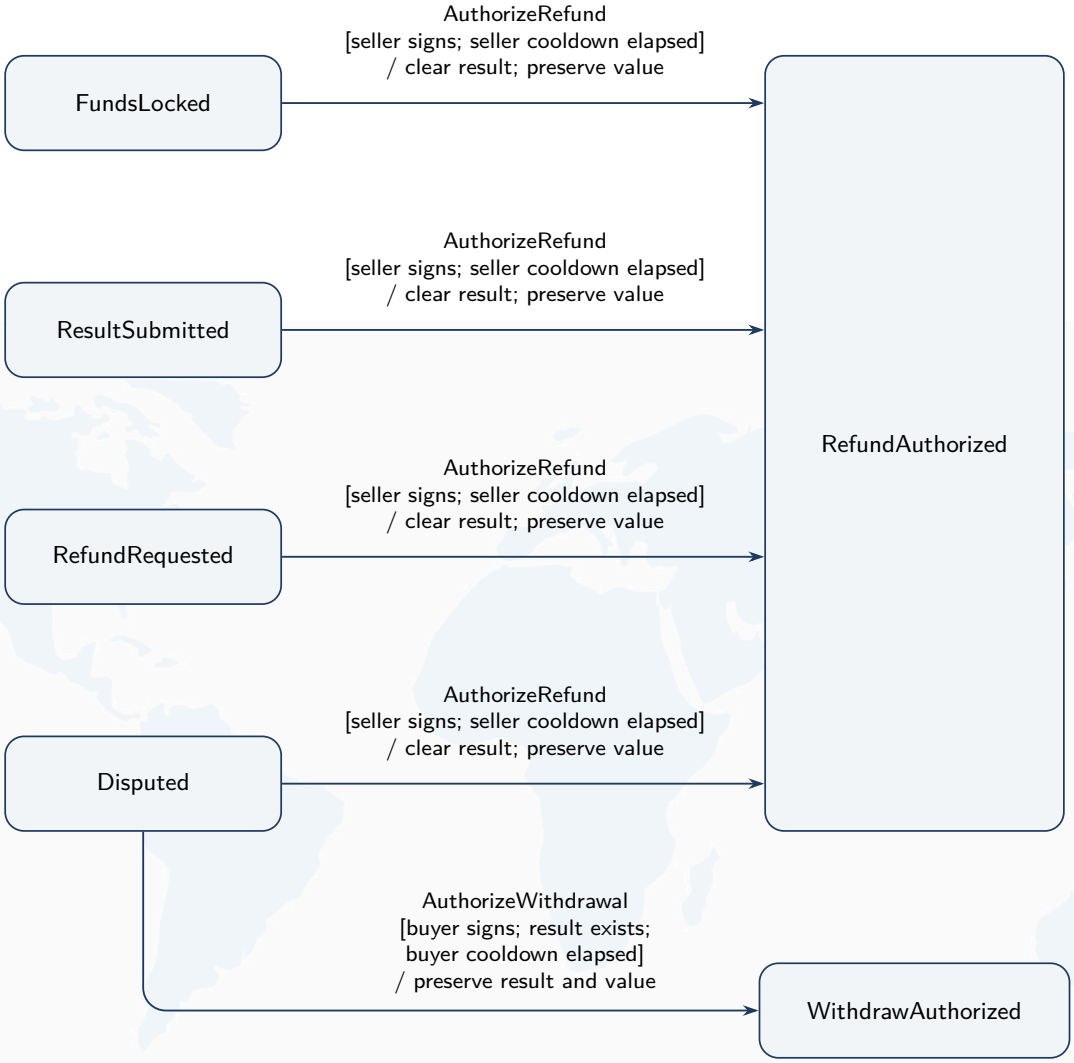
Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Diagram A.2. Mutual authorization

VERIFIED: Five transitions authorize a refund or a withdrawal. Each arrow has its own source state.



These transitions authorize a later spend. They do not release funds. AuthorizeRefund has no upper time limit. The guard table specifies the continuing datum and cooldown updates.

Source: `vested_pay.ak:460-502` and `vested_pay.ak:702-759`.

Key to Diagram A.3 and the edge table. FL: FundsLocked. RS: ResultSubmitted. RR: RefundRequested. D: Disputed. "Exit" and "Signed split" mean that the contract UTxO is spent, not a new datum state. A buyer or seller exit requires that actor's signature. Its destination is bound on chain only when the datum sets that actor's return address (`vested_pay.ak:304-344,419-450`). Any submitter can use `WithdrawDisputed` after the deadline if the redeemer has enough valid weighted admin signatures. Those signatures bind the spent output reference and the buyer and seller min-

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

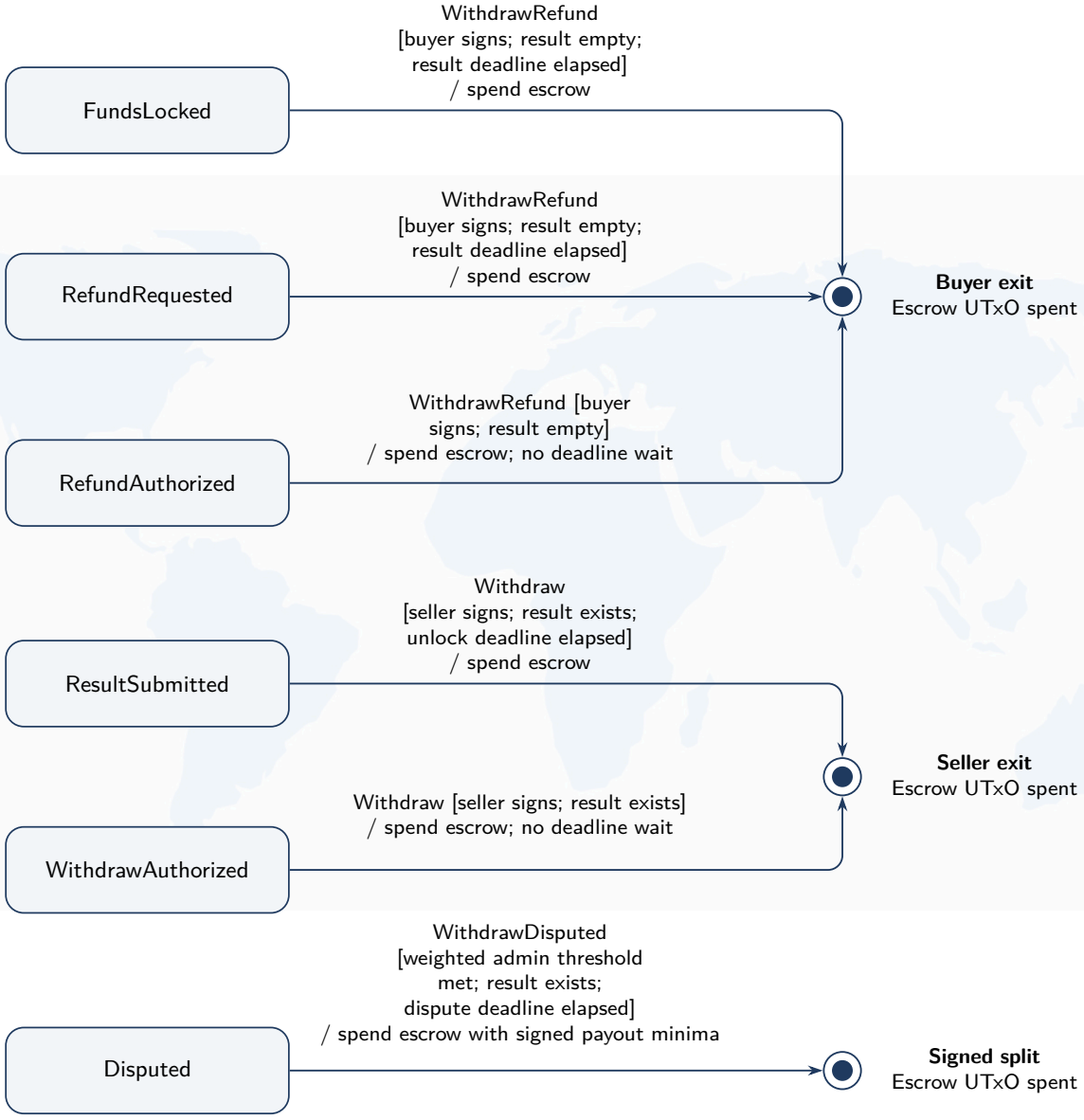
Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

imum payouts. Any residual value can pay the submitter (`vested_pay.ak:504-641`). Section 4.3 records the result-rotation check and the corrected signing guide.

Diagram A.3. Terminal spends

VERIFIED: Six transitions consume the escrow UTxO. The final markers describe termination, not new datum states.



A bullseye ends the escrow UTxO lifecycle. It is not a new datum state. Exit labels identify the authorized path; the guard table specifies return-address, reference-tag, collateral-return and payout-value rules.

Source: `vested_pay.ak:236-346`, `vested_pay.ak:407-458`, and `vested_pay.ak:504-641`.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

A.2 State and action edges

How we checked the edges. VERIFIED: We traced each action's source-state gate, signer, time bound, continuing datum, value, and tagged payout rules (`vested_pay.ak:101-233,236-760,769-806`). We also inspected the direct positive and rejection tests. REPORTED: The original review ran `aiken check` with 56 of 56 tests passing at `f48252c833cb`. VERIFIED: We reran `aiken check` on the unchanged validator source at the assessed revision. 56 of 56 tests passed (Section 8). The tests construct transactions for the validator. They do not prove live-chain behavior.

Action	Allowed state edges and guard	Audit evidence
SubmitResult	FL → RS; RS → RS; RR → D; D → D. The seller signs, meets the cooldown and deadline rules, and preserves the value.	Direct tests: FL and D (`vested_pay.ak:1426-1504`). RS and RR edges: source review only (`vested_pay.ak:643-700`).
SetRefundRequested	FL → RR; RS → D; D → D. The buyer signs before unlock and after cooldown. The result hash selects the next state.	Direct tests: FL and RS (`vested_pay.ak:1367-1423`). D self-loop: source review only (`vested_pay.ak:349-403`).
AuthorizeWithdrawal	D → WithdrawAuthorized. The buyer signs. The result hash must exist.	Direct test (`vested_pay.ak:1507-1538`). State and value checks (`vested_pay.ak:460-502`).
AuthorizeRefund	FL, RS, RR, or D → RefundAuthorized. The seller signs and clears the result hash.	Direct test: FL (`vested_pay.ak:1541-1573`). Other source states: source review only (`vested_pay.ak:702-759`).
Withdraw	RS → seller exit after unlock. WithdrawAuthorized → seller exit without that wait. The seller signs. No continuation with the same payment reference remains.	Both paths have direct tests (`vested_pay.ak:1576-1623`). Payout rules (`vested_pay.ak:236-346`).
WithdrawRefund	FL or RR → buyer exit after the result deadline. RefundAuthorized → buyer exit without that wait. The buyer signs. The result hash is empty.	Direct tests: FL and RefundAuthorized (`vested_pay.ak:1626-1669`). RR path: source review only (`vested_pay.ak:407-458`).
WithdrawDisputed	D → signed split after the dispute deadline. Weighted admin signatures bind the output reference and the minimum payouts. Any party may submit.	Unit signature vectors use zero payouts (`vested_pay.ak:1981-2121`). VERIFIED: The separate harness uses nonzero tagged payouts. REPORTED: A retained Preprod settlement was accepted. Section 4.3 gives the source and transaction references. No fresh funded settlement ran here.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

VERIFIED: These are all 18 state and action edges in the intended lifecycle. The source checks only parseable input datums at spend time. It does not validate lock creation (`vested_pay.ak:101-137`).

Limit. VERIFIED: This review did not rerun a funded Head or a live L1 transaction for each edge. REPORTED: The operator reports settlement and contract checks complete. Independent live-contention evidence is not retained in this review.

A.3 Security pattern checklist

Key. C: we inspected a control and found no exploit. N: the pattern does not apply. O: independent live-run evidence is not retained in this review. These are review decisions, not formal proofs. Line numbers refer to `vested_pay.ak`.

ID	Pattern		Evidence or limit
1	Double satisfaction	C	A distinct `reference_signature` for each input and output, and own-reference payout tags. Lines 150-233, 773-806.
2	Datum hijacking	C	Datum parse and actor checks for each action. Lines 101-136, 236-768.
3	Unbounded protocol datum	C	Fixed datum fields. Lines 41-67. The redeemer signature count is limited at lines 627-641.
4	Missing signer checks	C	A buyer, seller, or admin gate for each action. Lines 261, 392, 413, 495, 631-641, 689, 750.
5	Missing staking checks	C	The payout filter compares the full `Address`. Lines 773-806.
6	Arbitrary datum	C	Continuing outputs keep immutable fields and state. Lines 354-381, 463-491, 652-682, 720-744.
7	Arbitrary redeemer	C	Dispute values need admin signatures and tagged payouts. Lines 555-641.
8	Insufficient staking control	N	No staking validator.
9	Value not preserved	C	Continuing value rule and exit payout rules. Lines 298-335, 769-770.
10	Infinite minting	N	A spending validator. Registry minting runs on L1.
11	Token dust	C	A malformed input datum is filtered. Lines 153-166.
12	Contention	O	REPORTED: The operator reports contract checks complete. This review did not rerun live contention or retain independent results for it.
13	Withdraw-zero bypass	N	No stake co-validator.
14	Reference input confusion	N	The validator reads no reference inputs.
15	Time range manipulation	C	A finite upper bound and explicit time checks. Lines 138-141.
16	Missing deadline	C	Time gates for each action. Lines 236-768. Tests at lines 1136-1200.
17	Output ordering	C	Outputs are found by address and tag, not by index. Lines 773-806.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

ID	Pattern		Evidence or limit
18	Hardcoded addresses	C	Addresses come from the datum or the parameters. Lines 41-67, 96-100.
19	Datum transitions	C	State and field checks for each action. Lines 354-768.
20	Collateral handling	C	VERIFIED: The V2 L1 builder sets a collateral input and total collateral, evaluates the script before the final build, and normally holds the collateral UTxO out of spend selection (`single-interaction.ts:175-210,344-375`). A batch test rejects collateral and spend overlap (`batch-helpers.test.ts:402-429`). A phase-2 failure can still consume collateral. No deliberate live failure was run.
21	Script hash mismatch	C	VERIFIED: The V2 builder derives its address from the committed blueprint. Seeding rejects a derived address that differs from the configured Preprod or Mainnet address (`contract-generator.ts:63-76`; `prisma/seed.ts:419-433,701-714`). REPORTED: A Preprod E2E spent a UTxO locked by the current blueprint (`docs/migrations/v2-contract-cip30-upgrade.md:76-88`). This checks the tested script hash. Mainnet witness bytes were not compared.
22	Plutus version	C	Plutus V3 in `aiken.toml`.
23	Missing NFT authentication	C	A reference signature and an own-reference tag for each payment, not one global state token. Lines 150-233.
24	Redeemer size	C	Signature count and header size are limited. Lines 30, 627-641, 892-913.
25	Off-chain and on-chain mismatch	C	VERIFIED: The V2 builder loads the committed blueprint and supplies its script to spends (`contract-generator.ts:19-20,63-76`; `single-interaction.ts:330-338`). REPORTED: Recorded Preprod V2 L1 and L2 flows and a dispute E2E accepted transactions with this blueprint (`docs/hydra-l2-milestone4-report.md:92-114`; `docs/migrations/v2-contract-cip30-upgrade.md:76-88`). This supports the tested path.
26	State thread token	N	No state-thread token in this validator.

The payment path loads this script from `smart-contracts/payment-v2/plutus.json` (`packages/payment-source-v2/src/contract-generator.ts:19-20,63-76`). The earlier TxPipe audit (`docs/audit.pdf`, page 14) covers only the V1 contracts.

B Hydra API authorization

VERIFIED: The Payment Service reads its API key from the `token` header. All 56 handlers under `/api/v1/hydra/` use `adminAuthenticatedEndpointFactory.build` and require an active key with `canAdmin=`

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

`true` (`packages/payment-core/src/auth.ts:4`; `auth-middleware.ts:55-102`; `src/routes/api/index.ts:546-638`). Admin bypasses network and wallet-scope limits. A Pay key satisfies Read routes, but neither a Pay nor a Read key satisfies Admin (`packages/payment-core/src/permissions.ts:89-107`).

VERIFIED: A Host user bearer token is a separate credential from a Payment Service Read or Pay key. Host control routes use `Authorization: Bearer`. Only a Host admin bearer reaches provisioning and lifecycle routes (`packages/hydra-host/src/api/auth.ts:30-103`; `routes.ts:59-151`). The table maps logical access. INFERRED: Reachability depends on the deployed ingress and firewall, which this review did not inspect. Route checks and chain rules can still refuse an authorized request.

B.1 Trust-boundary diagrams

VERIFIED: These UML actor and component views map the access checks that the caller table in Section B.2 lists. The dashed enclosures are labeled security overlays. They do not add a UML privilege relationship.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

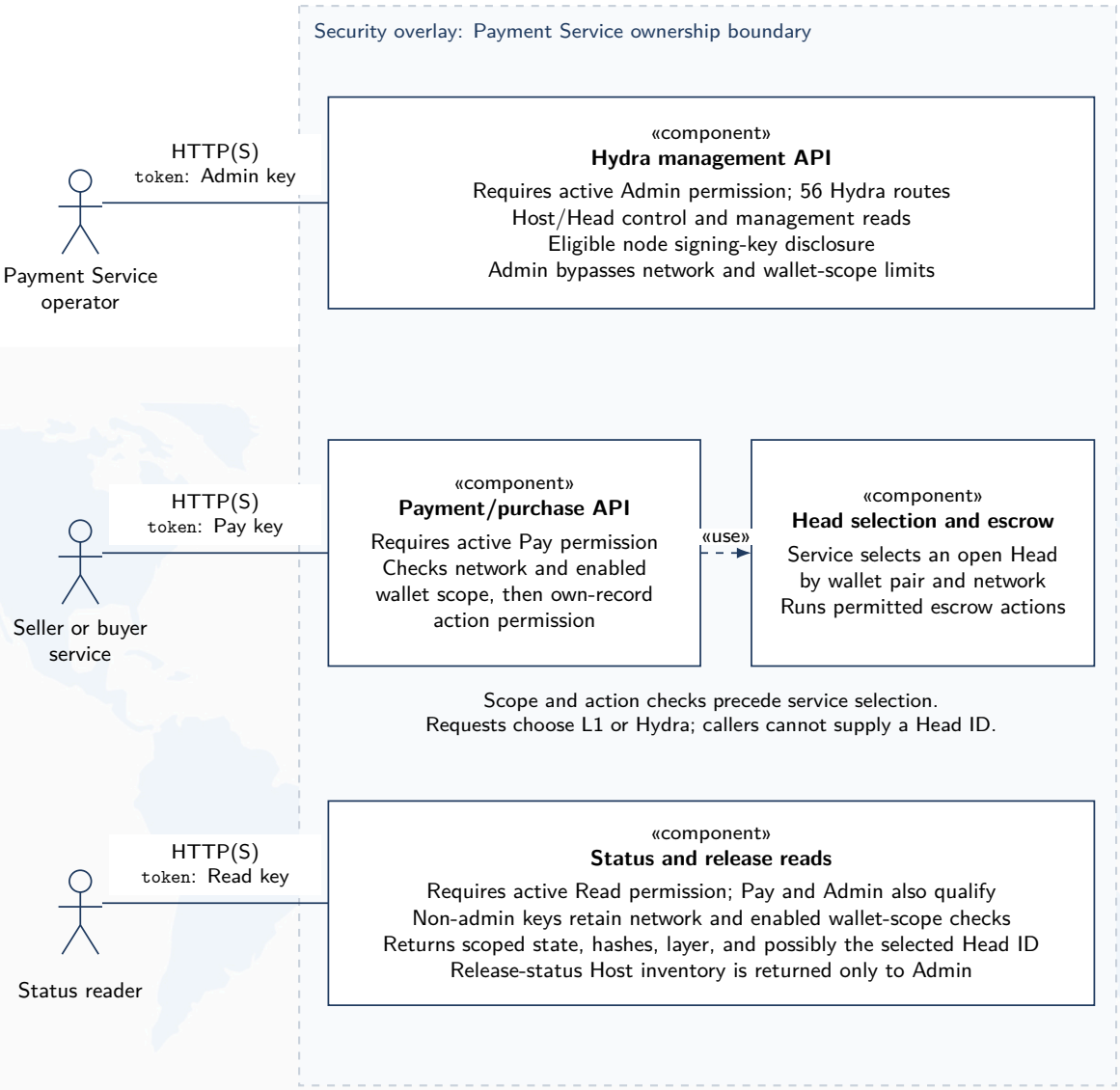
Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Diagram B.1. Payment Service authorization paths



Solid links show communication. The dashed arrow is a UML usage dependency.
The dashed enclosure is a security ownership overlay, not a UML privilege flow.
A returned Head ID identifies a resource; it grants no Hydra management authority.

VERIFIED: Source: `packages/payment-core/src/permissions.ts:89-107`; `src/routes/api/hydra/`; `payments/index.ts:89-118,273-344`; `release-status/index.ts:35-47`. The caller table in Section B.2 gives the remaining route references.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

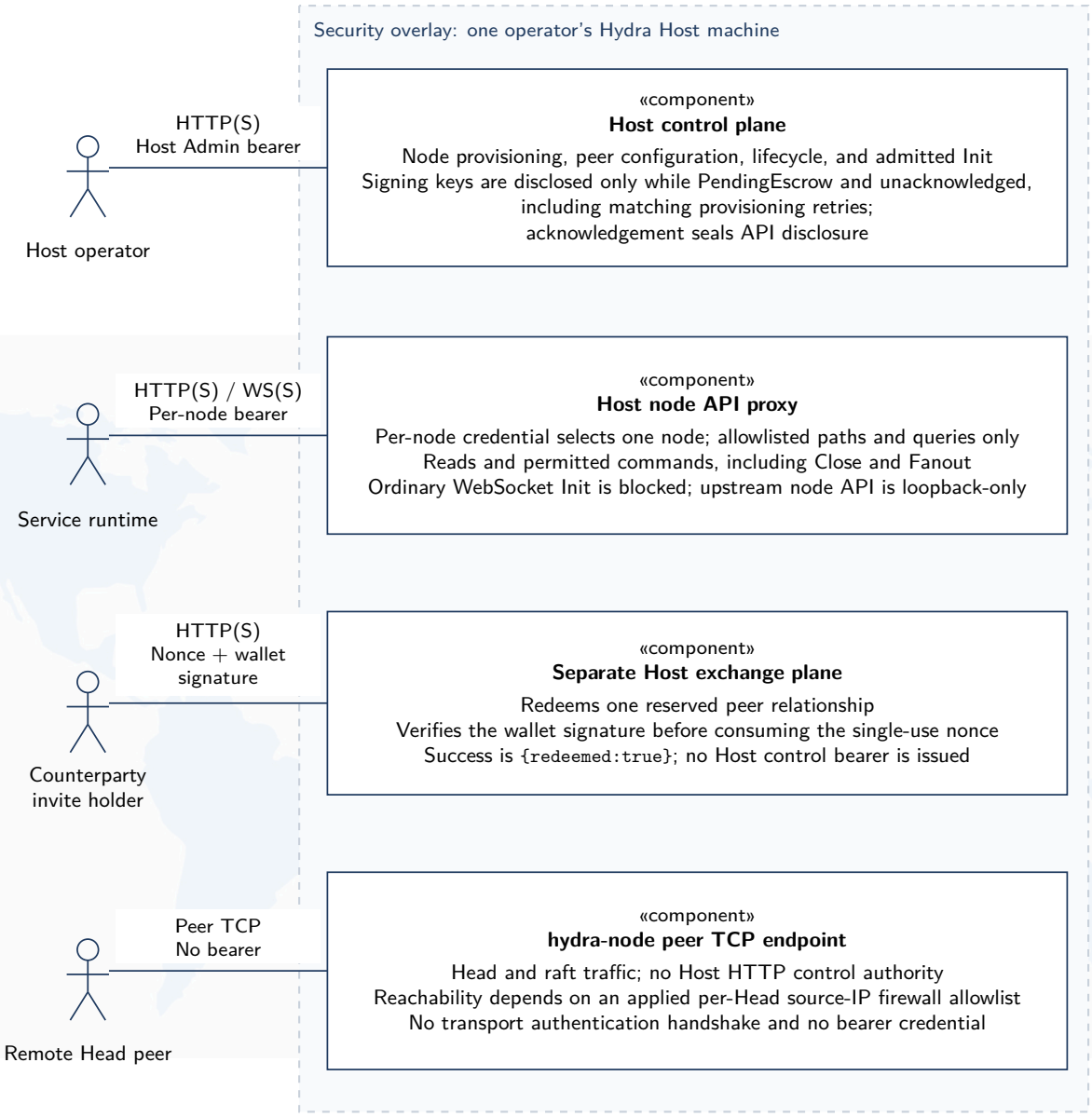
Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Diagram B.2. Host, counterparty, and peer paths



Solid links show separate communication paths. The dashed enclosure is a security ownership overlay, not a UML privilege flow. A firewall allowlist is a reachability condition, not transport authentication. Admin may also use node routes. The legacy Host-wide user bearer spans nodes while enabled. TLS terminates at ingress; the Host listeners use HTTP and WebSocket.

VERIFIED: Source: `packages/hydra-host/src/api/auth.ts:30-103`; `routes.ts:59-151`; `provision.ts:163-197`; `exchange-server.ts:479-584`; `peer-allowlist.ts:166-209`. See the caller table in Section B.2 for the node-proxy scope.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

B.2 Caller, credential, and exposure

Caller	Required credential and scope	Exposed data and possible effect
Payment Service operator	Active `canAdmin` API key in the `token` header. No network or wallet-scope limit.	Can read invite nonces, Host and Head topology, balances, errors, and transactions. Can run the 56 Hydra management routes. The one-time participant-key route can disclose an eligible node's Hydra and Cardano signing keys (`participant/index.ts:582-633`).
Seller or buyer service	Active `canPay` API key in `token`. The network limit applies. The wallet limit applies when wallet scope is enabled.	Can create payment or purchase records and request allowed actions on its own records. It can choose L1 or Hydra, but it cannot supply a Head ID or call Hydra management routes (`payments/index.ts:89-118,273-344`; `purchases/index.ts:79-109`; `payments/submit-result/index.ts:31-68`).
Status reader	Active `canRead` API key in `token`. Pay and Admin also satisfy Read. Network and enabled wallet scope apply to non-admin keys.	Can read permitted payment and purchase state, transaction hashes, layer, and a returned Head ID. `/release-status` returns service release data, but its Host list is empty without Admin (`payments/queries.ts:54-80`; `payments/schemas.ts:192-245`; `release-status/index.ts:35-47`).
Host operator	Host admin bearer token, separate from the Payment Service key.	Can list and control nodes, peer settings, invites, and Init. Provisioning can return new node secrets while escrow is pending. It does not give a general read of sealed existing keys (`packages/hydra-host/src/api/routes.ts:59-151`; `provision.ts:163-197`).
Host node client	Per-node derived bearer token, or Host admin bearer. The legacy Host-wide user token reaches all nodes while its option is enabled, which is the default.	Can read that node's Head and snapshot state and send allowlisted node API requests. WebSocket commands can Close or Fanout. Ordinary WebSocket Init is blocked. A per-node token cannot manage other nodes or Host admin routes (`auth.ts:67-103`; `config.ts:114-123`; `proxy-path.ts:30-38`; `proxy.ts:271-307`).
Counterparty invite holder	Open invite nonce plus a valid signature from its wallet. No Payment Service or Host bearer key is granted.	Can redeem one reserved peer relationship through the separate Host Exchange Plane. The success reply is only `\{redeemed:true\}`. An exposed open invite could be claimed by another wallet before the intended peer (`exchange-server.ts:1-21,479-503,561-584`).

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Caller	Required credential and scope	Exposed data and possible effect
Head network peer	No transport credential or bearer token. An applied per-Head IP firewall allowlist limits source addresses.	Can send peer and raft traffic to that Head's port. The peer plane has no authentication handshake. Peer-port reachability does not grant Host HTTP control (`packages/hydra-host/src/api/peer-allowlist.ts:1-13,166-209`; `routes.ts:59-151`).
Unauthenticated visitor	No credential, if the Host control listener is reachable.	Can read static Host documentation and OpenAPI metadata. Stateful control and node API paths require bearer authentication (`packages/hydra-host/src/api/server.ts:226-273`).

B.3 Admin route inventory and impact

Every route in the next table requires the Payment Service Admin key. Paths are relative to `/api/v1/hydra/`. INFERRED: The effects describe what a compromised Admin key could request. They do not bypass route guards or ledger validation.

Area	Routes	Exposure or effect
Invites	`GET, POST, DELETE invite`, `POST invite/preview`, `POST invite/redeem`	Reads include an open nonce and peer details. Issue or redeem reserves nodes and peer ports.
Hosts	`GET, POST, PATCH, DELETE host`, `POST host/check`, `GET, POST host/pause`, `POST host/resume`	Host identity, version, and status. Changes can alter Host access or availability. Stored Host tokens are not returned in normal reads.
Wallet base	`GET, POST wallet-base`	Reads or ensures the wallet base used to match a seller to a Head.
Relations	`GET, DELETE relation`	Reveals peer relationships. Deletion can break future pairing, subject to deletion guards.
Head lifecycle	`GET, PATCH head`, `POST head/init`, `POST head/commit`, `POST, GET head/topup`, `POST head/topup/recover`, `POST, GET head/withdraw`, `POST head/consolidate`, `POST head/close`, `POST head/fanout`, `GET, POST head/partial-fanout`, `POST head/retire`, `POST head/chain-check`	Reads Head identity and state. Mutations can move funds on allowed paths, change Head state, or interrupt settlement.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Area	Routes	Exposure or effect
Head operations	`GET, POST head/snapshot-round`, `GET head/l2-reservations` with release, stalled-release, and reapply, `GET head/balance`, `GET, DELETE head/errors`, `GET head/connection`, `GET head/transactions`	Exposes balances, snapshots, errors, and history. Reset and reservation actions affect recovery state.
Participants	`GET, DELETE participant/local`, `POST participant/local/keys`, `POST participant/local/withdraw`, `POST, GET, PATCH participant/local/fund`, `GET, DELETE participant/remote`	Exposes node and wallet identifiers. Key reveal is one-time. Funding and sweep move node fuel.
Alerts	`GET, POST, DELETE low-balance`	Reveals or changes low-balance monitoring rules.

VERIFIED: Outside this router, `GET /api/v1/release-status` requires Read permission. Pay and Admin keys also qualify. The response includes service release data for those callers, but a Hydra Host list only for Admin (`src/routes/api/release-status/index.ts:35-47`). Both `POST /api/v1/request-repair` and `POST /api/v1/request-repair/preview` require Admin. Forced repair of a Hydra request is refused (`src/routes/api/request-repair/index.ts:241,284-293,353`).

VERIFIED: Payment and purchase creation require Pay permission. Their input permits only an L1 or Hydra layer choice, not a caller-supplied Head ID. The service selects an open Head by wallet pair and network (`src/routes/api/payments/index.ts:89-118`; `purchases/index.ts:79-109`; `payments/schemas.ts:312-380`; `purchases/schemas.ts:292-381`; `src/utils/hydra/resolve-hydra-head.ts:80-121`). Read responses can return the selected Head ID with transaction state. This is disclosure of an identifier, not authority to control the Head (`payments/schemas.ts:192-245`; `purchases/schemas.ts:186-239`).

C L1 transaction retries

Each row records how a retry or a restart behaves for one L1 action.

Action	Signer	Behavior on retry or restart	Result
Initial commit	Wallet and node	The hash and the time to live are stored before submission. A retry reconciles first.	Safe
Top-up deposit	Wallet and node	Same as commit. The source also blocks another top-up while a confirmed deposit remains unabsorbed.	Source guard checked.
UTxO pre-split	Wallet	The source gives the transaction a validity bound and records the pending split.	Source guard checked.
Decommit	Wallet on L2, node on L1	The decommit ID is stored before the request. An unknown result stays pending.	Safe

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

Action	Signer	Behavior on retry or restart	Result
Init	Node	The assessed revision records a database token and a Host node marker before dispatch. Local database concurrency, persistence, release and retry, and state guards passed. A later retry must reconcile first.	Local checks verified. No chain dispatch.
Close	Node	A database latch under a Head row lock.	Safe
Fanout	Node	Each step spends the Head output, so a duplicate conflicts on chain.	Safe
Contest	Node	hydra-node posts it. The source alerts on observation failures and on an independent L1 Close.	Node still needed.
Deposit recover	Node	An operator acknowledgement, a 5-minute gap, and an L1 check before a retry.	Safe
Node funding	Wallet	One transfer in flight for each address. The hash is stored before submission.	Safe
Node sweep	Node	Spends all node outputs, so a retry conflicts on chain.	Safe

D Control evidence

D.1 Fanout limits and transaction size

REPORTED A three-node Hydra 2.4.1 test with preprod limits fanned out a 15,468-byte output. A 15,469-byte output made a 16,385-byte L1 transaction, which L1 rejected. The fanout overhead for one output was 917 bytes (`docs/hydra-fanout-output-size-measurement.md:8-31`).

VERIFIED The L2 limit is 15,000 bytes (`packages/hydra-host/src/ledger-params.ts:28-63`). Before the payment API sends Init, it compares live L2 limits with L1 (`src/services/hydra-host/init-ledger-admission.ts:34-81`). Ordinary Host WebSocket Init is blocked (`packages/hydra-host/src/api/proxy.ts:289-304`). The admin-only direct Init route also checks live L2 limits against current L1 Blockfrost parameters, and it refuses unsafe or unavailable results before dispatch (`packages/hydra-host/src/api/privileged-init.ts:19-20`; `init-admission.ts:96-135`). L2 submission checks the signed CBOR size (`src/lib/hydra/hydra/l2-tx-size.ts:16-20`).

INFERRED 15,000 plus 917 bytes leaves 467 bytes below the 16,384-byte L1 limit for one output. The margin depends on the Hydra version and the L1 parameters. Heads that started with older limits need a direct review.

VERIFIED The partial-fanout route selects only from the remaining node UTxO and blocks concurrent actions (`src/routes/api/hydra/head/partial-fanout.ts:165-203`). The L1 verifier checks the fanout sequence and the final token burn (`src/lib/hydra/hydra/fanout-validation.ts:494-613`).

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

D.2 L2 minting guards

VERIFIED No payment or Hydra path builds an L2 mint or burn. Replay adds the net mint of each transaction with `BigInt` (`src/lib/hydra/hydra/l2-mint-tally.ts:88-144`).

VERIFIED The provider and the decommit selector do not spend unburned or unverified tokens (`src/lib/hydra/hydra/provider.ts:117-136`, `src/services/hydra-decommit/select.ts:108-132`). A Head error records an unburned mint and warns that the final fanout is blocked (`src/services/hydra-head-error/unburned-l2-mint.ts:63-83`).

Operator procedure

Before Close, read the net L2 mint. If possible, burn each positive net unit on L2 and confirm a snapshot with zero net mint.

D.3 Snapshots, restart, and recovery

VERIFIED The signature verifier checks the signature of every configured party over the Hydra 2.4 snapshot hash. History replay calls this verifier (`src/lib/hydra/hydra/snapshot-signable.ts:61-91`, `snapshot-verification.ts:269-300`, `node-history-replay.ts:582-595`).

VERIFIED On boot, the Host adopts nodes that respond. It marks a dead node as Stopped and undrained (`packages/hydra-host/src/supervisor/supervisor.ts:103-208`). A command timeout after dispatch counts as an unknown result (`src/lib/hydra/hydra/node-command-channel.ts:119-185`).

VERIFIED Automatic side-load is off by default. When it is on, the Host still holds back if the state is unreadable or a deposit is unsettled (`packages/hydra-host/src/supervisor/unwedge.ts:210-275`).

VERIFIED Deposit recovery refuses a deposit that a snapshot holds. Before a retry, it needs an operator acknowledgement, a time gap, and fresh L1 and node checks (`src/services/hydra-topup/recover.ts:229-349`).

REPORTED A project drill on hydra-node 2.3.0 recovered from the loss of one node's storage. The other node closed the Head and fanned out (`docs/hydra-persistence-recovery-verification.md:7-45`).

REPORTED The upgrade ADR tells operators to close old Heads before an upgrade that changes the snapshot format (`docs/adr/0012-hydra-snapshot-verification-and-upgrades.md:119-137`).

D.4 Wallet signing and deposits

VERIFIED The service refuses an initial commit while a Head is `Initializing` (`src/routes/api/hydra/head/commit.ts:84-103`).

VERIFIED Before a wallet signs, the service checks the Init transaction on L1 for the Head output,

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

the state token, the parties, and the Open datum (`src/lib/hydra/hydra/head-init-validation.ts:210-227,296-327`). It checks the deposit output, its value, its datum, and its validity bound (`commit-draft-validation.ts:169-231`).

D.5 Hydra Host

VERIFIED Node routes accept a per-node HMAC token, the admin token, or the Host-wide user token (`packages/hydra-host/src/api/auth.ts:67-102`). A node token is bound to the path segment that selects the node.

VERIFIED The proxy always connects to `127.0.0.1` on the recorded node port. The node ID must match `^[A-Za-z0-9_-]{1,64}$`, and the sub-path must match an allowlist entry exactly (`packages/hydra-host/src/api/proxy.ts:29,39`, `proxy-path.ts:16-62`).

VERIFIED The exchange plane verifies the wallet signature before it uses the single-use invite nonce. It limits body size, concurrency, and requests for each source (`packages/hydra-host/src/api/exchange-server.ts:38-86,434-497`).

VERIFIED Both servers catch errors in their request handlers (`server.ts:213-326`, `exchange-server.ts:358-402`). The Host has no process-level exception handler, so a future unguarded error stops the process.

VERIFIED Node keys come from `crypto.randomBytes(32)` (`packages/hydra-host/src/keys.ts:92,98`). Ordinary node reads expose verification keys. Admin provisioning returns signing keys only while the record is `PendingEscrow` and unacknowledged, including matching idempotent retries. It returns `secrets:null` after acknowledgement (`packages/hydra-host/src/api/provision.ts:95-98,192-196,246-251`; `server.spec.ts:377-393`).

VERIFIED A released peer port stays unavailable until the Host accepts a new firewall acknowledgement (`packages/hydra-host/src/registry/ports.ts:149-156,255-289`).

D.6 Container and deployment

VERIFIED The Dockerfile pins the hydra-node and Node base images by digest, checks the etcd archive hash, and runs as user 10001 (`packages/hydra-host/Dockerfile:40,59,76-88,93,252-275`).

VERIFIED The base Compose file publishes the control and exchange ports on loopback only. Monitoring is off by default (`docker-compose.yml:42-47,108-111`). Each node API binds to `127.0.0.1` (`src/supervisor/args.ts:138-150`).

VERIFIED The public-peer override opens the peer ports on all interfaces (`docker-compose.public-peer.yml:30-42`). It requires a firewall acknowledgement value, but it cannot check that a firewall exists.

VERIFIED The production guide's Docker example uses host networking, mounts the egress receipt read-only, and sets both firewall requirements to true (`docs/hydra-host-deploy-droplet.md:177-221`). Its example systemd unit runs the inbound and egress firewall

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

baselines with `ExecStartPre` before each `docker start` (`docs/hydra-host-deploy-droplet.md:291-321`). The helpers load and read back their nftables rules, and the egress helper writes a receipt only after verification (`packages/hydra-host/scripts/hydra-peer-firewall:93-113,126-129`; `packages/hydra-host/scripts/hydra-peer-egress:151-188`). The Host checks that fresh receipt at start (`packages/hydra-host/src/index.ts:124-127`; `packages/hydra-host/src/peer-egress-attestation.ts:10-46`).

VERIFIED **Limit:** we checked the guide and the source, not a deployed host. The installed systemd unit, the container settings, and the live nftables rules were not inspected. Their compliance is not determined.

D.7 Invite lifecycle controls

REPORTED The historical D7 plan describes replay, idempotency, abandonment, and decline properties for OFFER, ACCEPT, and DECLINE messages (`docs/plans/2026-07-28-hydra-host-implementation.md:563-573`). The current signed invite and redemption flow uses different messages.

VERIFIED The signed invite binds its nonce, expiry, network, issuer wallet, keys, peer address, periods, and ledger hash (`src/services/hydra-invite/invite-payload.ts:20-101`). Verification checks the signature against the wallet named in that invite. The operator must confirm that address through a separate trusted channel (`invite-signing.ts:86-97`).

VERIFIED The Host Exchange Plane verifies a redeemer signature before it calls the exchange store (`packages/hydra-host/src/api/exchange-server.ts:485-497,561-584`). The store serializes its check and write. Equal signed material replays without a new write. Different material returns 409. An unused expired nonce returns 410 (`packages/hydra-host/src/registry/exchange-store.ts:206-252`).

VERIFIED An earlier local test (commit `b3dc461e93a5`, not on `dev`) sent real Mesh wallet signatures over Host HTTP. It checked an unchanged persisted redemption after the listener and store were recreated from disk. It also checked a 200 retry by the same wallet, 409 for another valid wallet, and 401 for altered signed material (`packages/hydra-host/src/registry/redemption-signature.spec.ts:150-165,191-209`). Its final suite passed 8 of 8 tests. That test stubbed `onRedeemed`, so it does not prove the Payment Service database invariant. The current integration uses the actual recovery callback and real PostgreSQL (Section 4.2).

VERIFIED The Payment Service expiry reaper checks Host redemptions before it forgets an invite (`src/services/hydra-invite/adoption.ts:520-592`). Admin revocation checks for a held redemption and requires an explicit discard to cancel it (`src/routes/api/hydra/invite/index.ts:504-575`). Host teardown releases a peer port only after the node record is removed (`packages/hydra-host/src/supervisor/teardown.ts:192-214`).

Coverage. VERIFIED: Section 4.2 records the current local component integration, its results, and its

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1

limits. The Exchange Plane has no signed counterparty decline route. Admin revoke is the current cancellation path.

E Evidence bundle

The checks at the assessed revision and the release checks produced the files below. The assessor retains them as the evidence bundle and can supply them on request.

File	Contents
`migrations.log`	Prisma migration run. All 169 migrations applied to PostgreSQL 18.6.
`init-local-check.mts`, `init-local-check.log`	The local Init admission harness and its results (Section 4.2).
`init-local-negative.log`	The negative control with the dispatch-token check removed.
`init-routes-node24.log`	Init route and Host provider suites, 46 of 46 tests.
`invite/`	The signed invite integration: test specification, Host worker, run script, Jest configuration, integration log, Payment retry log, and result record.
`host-controls-node24.log`	Nine Host control suites, 212 of 212 tests.
`payment-aiken.json`, `registry-aiken.json`	`aiken check` summaries for both V2 contracts.
`typechecks.json`	Backend and frontend TypeScript check exit codes.
`image-local-packages.json`, `image-local-smoke.log`, `image-local-hydra-probe.log`	The local Hydra Host image preflight (Section 4.5).
`release/`	Published image verification. GitHub release, tag, run, and job records. Image index and immutable index. Image configuration and platform manifest. Attestation descriptors. SLSA provenance and SPDX SBOM. Signed manifest, its signature, public key, and signature verification output. The `verify-release-image` script. Smoke probe script, log, and exit record.
`sha256.json`	SHA-256 of every file above.

Gesellschaft mit beschränkter Haftung
HRB: 621066 / Amtsgericht Freiburg im Breisgau

Finanzamt Waldshut-Tiengen
Steuernummer: 20029/84206
USt-IdNr.: DE 166274921

Geschäftsführer:
Reimund Schilder
Sascha Tobler

Bankverbindungen:
Sparkasse Hochrhein
BLZ: 684 522 90
Kto.: 758 95 18
IBAN: DE02 6845 2290 0007 5895 18
BIC/SWIFT: SKHRDE6W

Volksbank Hochrhein
BLZ: 684 922 00
Kto.: 215 47 57
IBAN: DE06 6849 2200 0002 1547 57
BIC/SWIFT: GENODE61WT1